



République Tunisienne

Ministère de l'Enseignement Supérieur
et de la Recherche Scientifique

École Supérieure Privée d'ingénierie et de technologie

TEK-UP



RAPPORT DE PROJET DE FIN D'ÉTUDES

Présenté en vue de l'obtention du

Licence en Cybersécurité

Spécialité : Cybersécurité

Réalisé par

Khaled Saidi

Conception et Implémentation d'une Infrastructure de Sécurité pour une Plateforme Événementielle en Ligne Optimisée par l'IA

Encadrante académique : Mme Nour Barrani

Encadrante académique

J'autorise l'étudiant à faire le dépôt de son rapport de stage en vue d'une soutenance.

Encadrante académique, **Mme Nour Barrani**

Signature

Dédicace

*À mes parents, pour leur soutien indéfectible
et leurs sacrifices inestimables tout au long
de mon parcours académique.*

*À mes proches et amis,
qui ont su m'encourager dans les moments difficiles.*

*À tous ceux qui croient en la valeur de la connaissance
et s'engagent à bâtir un monde numérique plus sûr.*

Khaled Saidi

Remerciements

Je tiens à exprimer ma profonde gratitude à l'ensemble des personnes qui ont contribué, de près ou de loin, à la réalisation de ce projet de fin d'études.

En premier lieu, je remercie chaleureusement **Mme Nour Barrani**, mon encadrante académique, pour sa disponibilité, ses conseils avisés et la rigueur scientifique qu'elle m'a transmise tout au long de ce travail. Son accompagnement constant a été déterminant dans la conduite de ce projet.

Je témoigne également ma reconnaissance à l'ensemble du corps enseignant du département Informatique de l'Université TEK-UP Tunisie, dont les enseignements dispensés au fil de ma formation m'ont fourni les fondements théoriques et pratiques nécessaires à l'accomplissement de ce travail.

Mes remerciements s'adressent aussi au jury qui a accepté d'évaluer ce rapport et de consacrer son temps à l'examen de mes travaux.

Enfin, je remercie ma famille et mes amis pour leur soutien moral et leurs encouragements qui m'ont permis de persévérer jusqu'à l'aboutissement de ce projet.

Table des matières

Liste des Abréviations	vii
Introduction Générale	1
1 Cadre du Projet	3
1.1 Présentation de l’Organisme d’Accueil	4
1.1.1 Présentation générale de TEK-UP	4
1.1.2 Secteur d’activité	4
1.1.3 Mission et valeurs	5
1.2 Contexte du Projet	5
1.3 Problématique	6
1.4 Objectifs du Projet	6
1.5 Méthodologie de Travail — SCRUM	7
1.5.1 Choix de la méthodologie agile	7
1.5.2 Organisation en sprints	7
1.5.3 Rôles et cérémonies SCRUM	8
1.5.4 Outils de gestion de projet	8
2 État de l’Art	10
2.1 Concepts Fondamentaux de la Cybersécurité	11
2.1.1 La triade CIA	11
2.1.2 Chiffrement et protocoles sécurisés	11
2.1.3 Authentification et gestion des identités	12
2.1.4 Modélisation des menaces — STRIDE	12
2.1.5 Cadres normatifs de référence	12
2.2 Gestion des Incidents de Sécurité	13
2.2.1 Cycle de vie d’un incident	13
2.2.2 Indicateurs clés — TTD et TTR	13
2.2.3 Conformité RGPD et notification des violations	13
2.3 Supervision Réseau	13
2.3.1 Définition et enjeux	13
2.3.2 Protocoles et technologies de supervision	14

2.3.3	Supervision dans les architectures conteneurisées	14
2.4	Intelligence Artificielle Conversationnelle	14
2.4.1	Traitement du Langage Naturel (NLP)	14
2.4.2	Chatbots et assistants intelligents	15
2.4.3	Agent de traduction multilingue	15
2.5	SOC et SIEM — Perspectives de sécurité opérationnelle	16
2.5.1	Security Operations Center (SOC)	16
2.5.2	SIEM — Security Information and Event Management	16
3	Spécification des Besoins	18
3.1	Identification des Acteurs	19
3.2	Spécification des Besoins Fonctionnels	20
3.2.1	Vue d'ensemble du système	20
3.2.2	Gestion des Événements et Authentification	21
3.2.3	Déroulement des Réunions Virtuelles	22
3.2.4	Intelligence Artificielle — Chatbot et Traduction	22
3.2.5	Gestion RGPD et Administration Système	23
3.3	Spécification des Besoins Non Fonctionnels	23
3.4	Études Comparatives des Outils Retenus	24
3.4.1	Plateformes de visioconférence	24
3.4.2	Progiciels ERP	25
3.4.3	Solutions de chatbot et d'IA conversationnelle	25
3.4.4	Fournisseurs d'infrastructure cloud	26
3.5	Justification Globale des Choix Techniques	26
4	Conception de l'Architecture	28
4.1	Architecture Globale du Système	29
4.1.1	Vue en couches	29
4.1.2	Justification des choix architecturaux	30
4.2	Modélisation Détaillée des Composants	32
4.2.1	Diagramme de classes	32
4.2.2	Diagramme de séquence	33
4.3	Architecture de Sécurité	35
4.3.1	Chiffrement des communications	36
4.3.2	Authentification multi-facteurs (MFA)	36

4.3.3	Contrôle d'accès basé sur les rôles (RBAC)	37
4.3.4	Conformité RGPD dans la conception	37
4.3.5	Analyse des menaces — Modèle STRIDE	38
4.3.6	Principes de Sécurité par Conception	38
4.3.7	Tests de Sécurité	39
4.3.8	Conformité RGPD — Articles adressés	39
4.4	Architecture de Déploiement	40
4.4.1	Conteneurisation avec Docker	40
4.4.2	Infrastructure OVHcloud	41
4.4.3	Pipeline CI/CD	41
5	Implémentation et Déploiement	43
5.1	Environnement de Développement	44
5.1.1	Outils et technologies	44
5.1.2	Structure du dépôt Git	45
5.2	Implémentation des Services Cœur	45
5.2.1	Service d'authentification	45
5.2.2	Gestion des événements via Odoo	45
5.3	Architecture et Implémentation du Chatbot IA	46
5.3.1	Objectif du chatbot	47
5.3.2	Architecture générale	47
5.3.3	Flux détaillé d'une requête	48
5.3.4	Gestion du contexte conversationnel	48
5.3.5	Sécurité du chatbot	48
5.3.6	Intégration à la plateforme	49
5.3.7	Cas d'utilisation réels	49
5.3.8	Bénéfices obtenus	50
5.4	Agent de Traduction Multilingue	51
5.4.1	Objectif et fonctionnement	51
5.4.2	Langues supportées et exemple	51
5.5	Implémentation de la Sécurité et du RGPD	51
5.5.1	Contrôle d'accès RBAC et authentification JWT	51
5.5.2	Droits RGPD	52
5.6	Tests et Validation	53

5.6.1	Stratégie de tests	53
5.6.2	Analyse des menaces STRIDE et contre-mesures implémentées	53
5.6.3	Résultats des tests fonctionnels	54
5.6.4	Tests de sécurité applicative	55
5.7	Déploiement Final	56
Conclusion Générale		58

Table des figures

1.1 Logo de l'université TEK-UP Tunis 4

Liste des tableaux

1.1	Organisation des sprints SCRUM du projet	8
2.1	Principaux cadres normatifs en cybersécurité	12
2.2	Comparatif des solutions SIEM — veille technologique	17
3.1	Identification des acteurs du système	20
3.2	Cas d'utilisation — Vue d'ensemble du système	20
3.3	Correspondance Besoins — Fonctionnalités — Solutions techniques	21
3.4	Cas d'utilisation — Gestion des Événements et Authentification	22
3.5	Cas d'utilisation — Déroulement des Réunions Virtuelles	22
3.6	Cas d'utilisation — Intelligence Artificielle : Chatbot et Traduction	23
3.7	Cas d'utilisation — Gestion RGPD et Données Personnelles (UC_R01 à UC_R10) . .	23
3.8	Synthèse des besoins non fonctionnels	24
3.9	Comparatif des solutions de visioconférence	24
3.10	Comparatif des solutions ERP	25
3.11	Comparatif des solutions de chatbot / IA conversationnelle	25
3.12	Comparatif des fournisseurs d'infrastructure cloud	26
3.13	Synthèse de la justification des choix techniques	27
4.1	Justification des choix technologiques	31
4.2	Description des classes du système	33
4.3	Correspondance menaces / mesures de protection (modèle STRIDE)	35
4.4	Matrice des rôles et permissions (RBAC)	37
4.5	Services Docker du système	40
5.1	Environnement et outils de développement	44
5.2	Routes API du module ai_healthcare_event	46
5.3	Composants techniques du chatbot IA par couche	47
5.4	Mécanismes de sécurité implémentés sur l'endpoint chatbot	49
5.5	Bénéfices du chatbot IA — axes et impacts	50
5.6	Langues supportées par l'agent de traduction	51
5.7	Matrice des rôles RBAC implémentée	52
5.8	Stratégie de tests — outils et objectifs	53

5.9	Analyse STRIDE étendue — Menace, Risque, Contre-mesure, Implémentation, Résultat	54
5.10	Résultats des tests fonctionnels	55
5.11	Résultats des tests de sécurité applicative	56
5.12	Architecture de déploiement — 7 conteneurs Docker	56

Liste des Abréviations

—	API	=	Application Programming Interface
—	CRUD	=	Create, Read, Update, Delete
—	DNS	=	Domain Name System
—	ERP	=	Enterprise Resource Planning
—	GDPR	=	General Data Protection Regulation
—	IA	=	Intelligence Artificielle
—	IDS	=	Intrusion Detection System
—	IPS	=	Intrusion Prevention System
—	JWT	=	JSON Web Token
—	LLM	=	Large Language Model
—	MFA	=	Multi-Factor Authentication
—	RBAC	=	Role-Based Access Control
—	REST	=	Representational State Transfer
—	RGPD	=	Règlement Général sur la Protection des Données
—	SRTP	=	Secure Real-time Transport Protocol
—	SSL	=	Secure Sockets Layer
—	TLS	=	Transport Layer Security
—	UC	=	Cas d'Utilisation (Use Case)
—	UI/UX	=	User Interface / User Experience
—	VPN	=	Virtual Private Network
—	WebRTC	=	Web Real-Time Communication

Introduction Générale

L’essor fulgurant des technologies de communication numérique a profondément transformé les modes d’organisation et de participation aux événements professionnels et académiques. Les plateformes de visioconférence sont désormais au cœur de la vie économique et sociale, rassemblant des milliers de participants à travers le monde en temps réel. Cette évolution s’accompagne cependant de risques croissants en matière de sécurité informatique : interception des flux de données, usurpation d’identité, violation de la vie privée et non-conformité aux réglementations en vigueur constituent autant de menaces auxquelles les opérateurs de ces plateformes doivent répondre.

C’est dans ce contexte que s’inscrit le présent projet de fin d’études, intitulé « *Conception et Implémentation d’une Infrastructure de Sécurité pour une Plateforme Événementielle en Ligne Optimisée par l’IA* ». L’ambition de ce travail est double : d’une part, bâtir une infrastructure de sécurité multicouche, conforme aux meilleures pratiques de la cybersécurité et aux exigences du Règlement Général sur la Protection des Données (RGPD) ; d’autre part, enrichir l’expérience des participants grâce à des services d’intelligence artificielle, notamment la transcription et la traduction automatiques en temps réel.

La plateforme proposée répond à un besoin métier concret : permettre à un organisateur de planifier, configurer et animer des événements en ligne, en s’appuyant sur des templates personnalisés et une synchronisation avec le progiciel de gestion Odoo. Les participants bénéficient quant à eux d’une interface accessible, sécurisée et multilingue, renforçant ainsi l’inclusivité et la portée internationale des événements hébergés.

Sur le plan méthodologique, ce projet suit un cycle de développement structuré, articulé autour des phases classiques du génie logiciel : analyse des besoins, conception architecturale, implémentation et validation. Ce rapport rend compte de l’intégralité de cette démarche, en présentant les choix techniques adoptés, les mécanismes de sécurité mis en œuvre et les résultats obtenus.

Le présent document est organisé en cinq chapitres principaux :

- **Chapitre 1 — Cadre du Projet** : ce chapitre présente l’organisme d’accueil (TEK-UP), le contexte et la problématique du projet, ses objectifs et la méthodologie agile SCRUM adoptée.
- **Chapitre 2 — État de l’Art** : ce chapitre dresse un panorama des domaines scientifiques et technologiques mobilisés — cybersécurité, gestion des incidents, supervision réseau, IA, SOC et SIEM.
- **Chapitre 3 — Spécification des Besoins** : ce chapitre identifie les acteurs, formalise

les besoins fonctionnels et non fonctionnels, présente les études comparatives et justifie les choix technologiques.

- **Chapitre 4 — Conception de l'Architecture** : ce chapitre présente l'architecture globale du système, la modélisation UML et les mécanismes de sécurité (STRIDE, RBAC, RGPD by Design).
- **Chapitre 5 — Implémentation et Déploiement** : ce chapitre décrit la mise en œuvre technique, les configurations de sécurité appliquées et les résultats des tests sur infrastructure OVHcloud.

CADRE DU PROJET

Introduction

Ce premier chapitre pose le cadre général du projet de fin d'études. Il présente l'organisme d'accueil, son secteur d'activité et ses valeurs, avant de contextualiser la problématique à laquelle répond le projet. Les objectifs poursuivis ainsi que la méthodologie de travail adoptée sont ensuite exposés, fournissant la vision stratégique et opérationnelle nécessaire à la bonne compréhension des chapitres techniques qui suivent.

1.1 Présentation de l'Organisme d'Accueil

1.1.1 Présentation générale de TEK-UP

TEK-UP est une université privée tunisienne fondée sur les principes de l'excellence académique, de l'innovation pédagogique et de l'ouverture internationale. Reconnue par le ministère de l'Enseignement Supérieur et de la Recherche Scientifique tunisien, elle accueille plusieurs milliers d'étudiants répartis au sein de ses différentes facultés spécialisées.

TEK-UP se distingue par une approche résolument orientée vers les technologies de l'information et de la communication, avec une offre de formation couvrant les domaines de l'informatique, du génie logiciel, de la cybersécurité, de l'intelligence artificielle, du management des systèmes d'information et des réseaux. Son modèle pédagogique met l'accent sur les projets pratiques, les partenariats avec l'industrie et l'employabilité des diplômés.



FIGURE 1.1 : Logo de l'université TEK-UP Tunis

1.1.2 Secteur d'activité

TEK-UP opère dans le secteur de l'enseignement supérieur privé et de la formation professionnelle en technologies de l'information. Ses activités principales s'articulent autour de :

- La formation initiale de niveau licence, master et ingénierie dans les filières informatiques et managériales ;
- La recherche appliquée en partenariat avec des entreprises du secteur technologique tunisien et international ;
- L’organisation d’événements académiques et professionnels (conférences, hackathons, forums entreprises) favorisant l’insertion professionnelle des étudiants ;
- Le développement de solutions numériques à travers ses laboratoires et ses projets de fin d’études encadrés par des experts du domaine.

1.1.3 Mission et valeurs

La mission de TEK-UP est de former des ingénieurs et des cadres compétents, éthiques et innovants, capables de répondre aux défis technologiques contemporains et de contribuer au développement économique de la Tunisie. Cette mission se décline autour de quatre valeurs fondamentales :

- **Excellence** : exigence académique et qualité des enseignements assurée par un corps professoral qualifié et des programmes régulièrement mis à jour selon les standards internationaux ;
- **Innovation** : encouragement de la créativité, de l’expérimentation et de l’entrepreneuriat technologique ;
- **Intégrité** : respect des règles éthiques, académiques et professionnelles dans l’ensemble des activités de l’institution ;
- **Ouverture** : partenariats avec des universités étrangères, mobilité étudiante et veille technologique internationale.

1.2 Contexte du Projet

Le présent projet de fin d’études s’inscrit dans le contexte de la transformation numérique accélérée des organisations, et plus particulièrement dans celui de l’essor des plateformes événementielles en ligne. Depuis 2020, la généralisation du travail à distance et des interactions virtuelles a profondément modifié les pratiques d’organisation d’événements professionnels et académiques : conférences, webinaires, formations, assemblées générales — autant d’activités désormais réalisées principalement en ligne.

Dans ce contexte, TEK-UP a identifié un besoin stratégique : disposer d’une infrastructure événementielle sécurisée et enrichie par l’intelligence artificielle, permettant d’organiser et d’animer des événements virtuels de grande envergure tout en garantissant la confidentialité des échanges, la conformité réglementaire et l’accessibilité multilingue des contenus.

Ce projet a été réalisé dans le cadre d’un stage de fin d’études de licence en informatique,

sous l’encadrement académique de l’encadrante Nour BARRANI. Il constitue à la fois un travail de recherche et développement et une réponse concrète à un besoin opérationnel identifié.

1.3 Problématique

L’organisation d’événements en ligne soulève plusieurs problématiques critiques auxquelles les solutions existantes sur le marché ne répondent que partiellement :

- **Sécurité des communications** : les plateformes grand public (Zoom, Teams, Meet) ont fait l’objet de nombreuses vulnérabilités documentées — intrusions non autorisées (Zoom-bombing), interception de flux, fuites de données — soulevant des inquiétudes légitimes quant à leur utilisation pour des réunions sensibles.
- **Conformité au RGPD** : les solutions américaines transfèrent des données personnelles vers des serveurs hors Union Européenne, en contradiction potentielle avec les exigences du Règlement Général sur la Protection des Données **rgpd**. Les organisations européennes ont besoin de solutions souveraines et conformes.
- **Accessibilité linguistique** : les barrières de langue limitent la participation effective à des événements internationaux. L’absence de transcription et de traduction automatiques en temps réel constitue un frein majeur à l’inclusivité.
- **Dépendance aux fournisseurs** : les solutions propriétaires imposent des contraintes de coûts, de personnalisation et de portabilité qui freinent leur adoption par des organisations de taille moyenne.

La problématique centrale de ce projet est donc : *Comment concevoir et implémenter une infrastructure événementielle en ligne qui combine robustesse sécuritaire, conformité réglementaire et intelligence artificielle au service de l’accessibilité ?*

1.4 Objectifs du Projet

Pour répondre à cette problématique, le projet poursuit quatre objectifs complémentaires :

1. **Conception d’une infrastructure de sécurité multicouche** : mettre en œuvre des mécanismes de protection complets — chiffrement des communications (TLS 1.3, SRTP), authentification multi-facteurs (MFA), contrôle d’accès basé sur les rôles (RBAC) et protection contre les menaces STRIDE — garantissant la confidentialité et l’intégrité des données.
2. **Intégration de l’intelligence artificielle** : déployer le modèle Whisper **whisper** pour la transcription automatique de la parole en temps réel et un service de traduction multilingue basé sur un LLM local, offrant des sous-titres instantanés aux participants.

3. **Conformité réglementaire RGPD** : intégrer dès la conception les principes de Privacy by Design — consentement explicite, droit à l’oubli, portabilité des données, pseudonymisation — conformément aux articles 5, 15, 17, 20 et 25 du RGPD.
4. **Déploiement cloud souverain et scalable** : déployer l’architecture sur infrastructure OVHcloud (datacenters européens), en utilisant Docker pour la conteneurisation et GitHub Actions pour le pipeline CI/CD, assurant une disponibilité de 99,9%.

1.5 Méthodologie de Travail — SCRUM

1.5.1 Choix de la méthodologie agile

La gestion de ce projet repose sur la méthodologie agile SCRUM, particulièrement adaptée aux projets de développement logiciel de complexité élevée, aux exigences évolutives et aux délais contraints. SCRUM favorise une livraison incrémentale de valeur, une adaptation continue aux retours des parties prenantes et une transparence maximale sur l’avancement du projet **microservices**.

Par opposition aux approches en cascade (waterfall), SCRUM permet de détecter et corriger rapidement les écarts par rapport aux objectifs, réduisant ainsi le risque d’un produit final inadapté aux besoins réels.

1.5.2 Organisation en sprints

Le projet a été organisé en quatre sprints successifs de deux à trois semaines chacun, couvrant l’ensemble du cycle de vie du développement :

Sprint	Objectif principal	Livrables
Sprint 1	Analyse des besoins, architecture et mise en place de l’environnement	Diagrammes UML, architecture détaillée, environnement Docker
Sprint 2	Développement des services d’authentification et de gestion des événements (module Odoo)	Auth Service (MFA/JWT), module Odoo <code>ai_healthcare_event</code>
Sprint 3	Intégration de l’intelligence artificielle (Whisper STT, LLM traduction) et de la visioconférence Jitsi	STT Service, Translation Service, intégration Jitsi Meet

Sprint	Objectif principal	Livrables
Sprint 4	Sécurisation complète, conformité RGPD, tests et déploiement sur OVHcloud	Routes RGPD, pipeline CI/CD, rapport final, déploiement production

TABLEAU 1.1 : Organisation des sprints SCRUM du projet

1.5.3 Rôles et cérémonies SCRUM

Les rôles SCRUM ont été adaptés au contexte académique du projet :

- **Product Owner** : l'encadrante académique, chargée de valider les livrables et de prioriser le Product Backlog ;
- **Scrum Master** : l'étudiant (Khaled SAIDI), garant du respect de la méthodologie et de la résolution des obstacles ;
- **Development Team** : l'étudiant, responsable du développement et de la livraison des incréments.

Les cérémonies SCRUM suivies ont été : le Sprint Planning (définition des objectifs et des tâches en début de sprint), la Sprint Review (présentation des livrables à l'encadrante) et la Sprint Retrospective (analyse des points d'amélioration). Des points de suivi hebdomadaires ont été maintenus tout au long du projet.

1.5.4 Outils de gestion de projet

Les outils suivants ont été utilisés pour la gestion du projet et la collaboration :

- **GitHub** : hébergement du code source, gestion des branches (Git Flow), revues de code et déclenchement des pipelines CI/CD ;
- **GitHub Projects** : tableau Kanban pour le suivi des tâches du Product Backlog et des User Stories en cours ;
- **Visual Studio Code** : environnement de développement intégré principal pour le développement des services Python et des configurations Docker/Odoo ;
- **Discord** : canal de communication et de partage de ressources avec l'encadrante.

Conclusion

Ce chapitre a établi le cadre général dans lequel s'inscrit le projet : une université technologique tunisienne innovante (TEK-UP), un besoin opérationnel concret en matière de sécurité événementielle numérique, et une méthodologie de travail agile (SCRUM) permettant une livraison itérative et contrôlée

de la solution. Les objectifs clairement formulés — sécurité multicouche, IA temps réel, conformité RGPD, déploiement cloud souverain — guident l'ensemble des choix techniques présentés dans les chapitres suivants. Le prochain chapitre s'attache à dresser l'état de l'art des domaines technologiques mobilisés par ce projet.

ÉTAT DE L'ART

Plan

1	Présentation de l'Organisme d'Accueil	4
2	Contexte du Projet	5
3	Problématique	6
4	Objectifs du Projet	6
5	Méthodologie de Travail — SCRUM	7

Introduction

Cette sous-section présente les fondements conceptuels nécessaires à la compréhension du projet et permet de situer les choix techniques retenus par rapport aux pratiques de référence. La revue bibliographique est structurée autour des quatre axes directement liés aux enjeux du projet : la cybersécurité appliquée à une plateforme événementielle, la gestion des incidents et la conformité réglementaire, la supervision réseau comme notion théorique, et l'intelligence artificielle au service de l'accessibilité des utilisateurs. Pour chaque domaine, la pertinence par rapport au projet est explicitée, et la distinction entre ce qui a été effectivement réalisé et ce qui relève d'une perspective d'évolution est clairement posée.

2.1 Concepts Fondamentaux de la Cybersécurité

2.1.1 La triade CIA

La cybersécurité repose sur trois propriétés fondamentales, connues sous l'acronyme CIA (Confidentiality, Integrity, Availability) :

- **Confidentialité (Confidentiality)** : garantir que l'information n'est accessible qu'aux entités autorisées. Elle est assurée techniquement par le chiffrement (AES-256 au repos, TLS 1.3 en transit) et organisationnellement par le contrôle d'accès **cryptography**.
- **Intégrité (Integrity)** : garantir que l'information n'est ni altérée ni détruite de manière non autorisée. Les mécanismes de hachage cryptographique (SHA-256, HMAC) et les signatures numériques permettent de détecter toute modification **cryptography**.
- **Disponibilité (Availability)** : garantir que les systèmes et les données sont accessibles en temps voulu aux utilisateurs légitimes. La résilience aux pannes, la redondance et la protection contre les dénis de service (DoS/DDoS) sont les principaux leviers.

2.1.2 Chiffrement et protocoles sécurisés

Le chiffrement est le pilier technique de la confidentialité. Les protocoles modernes de référence sont TLS 1.3 (Transport Layer Security), standardisé par l'IETF en 2018 via la RFC 8446, qui sécurise les échanges applicatifs sur TCP, et SRTP (Secure Real-time Transport Protocol, RFC 3711), optimisé pour les flux multimédias UDP dans les communications WebRTC **webrtc**.

L'algorithme AES-256 (Advanced Encryption Standard) est recommandé par le NIST pour le chiffrement des données au repos, offrant une résistance aux attaques par force brute considérée comme pratiquement insurmontable **nist**.

2.1.3 Authentification et gestion des identités

L'authentification multi-facteurs (MFA) combine plusieurs preuves d'identité — connaissance (mot de passe), possession (token OTP), inhérence (biométrie) — pour réduire drastiquement le risque de compromission de compte. L'usage du standard TOTP (RFC 6238) pour les codes à usage unique garantit la résistance aux attaques par jeu. Les JSON Web Tokens (JWT, RFC 7519) signés cryptographiquement constituent le standard de facto pour la gestion des sessions dans les architectures microservices **cryptography**.

2.1.4 Modélisation des menaces — STRIDE

Le modèle STRIDE **stride**, développé par Microsoft, est un cadre méthodologique d'identification des menaces selon six catégories : Spoofing (usurpation), Tampering (altération), Repudiation (répudiation), Information Disclosure (divulgaration), Denial of Service (déni de service) et Elevation of Privilege (élévation de privilèges). Ce cadre est aujourd'hui intégré dans les pratiques de Security by Design et recommandé par le NIST **nist**.

2.1.5 Cadres normatifs de référence

Plusieurs référentiels normatifs structurent la pratique de la cybersécurité :

Cadre / Norme	Périmètre	Organisme
NIST CSF 2.0 nist	Gouvernance, identification, protection, détection, réponse, rétablissement	NIST (USA)
ISO/IEC 27001	Management de la sécurité de l'information (SMSI)	ISO
RGPD rgpd	Protection des données personnelles dans l'UE	Parlement européen
OWASP Top 10	Vulnérabilités web les plus critiques	OWASP Foundation

TABLEAU 2.1 : Principaux cadres normatifs en cybersécurité

2.2 Gestion des Incidents de Sécurité

2.2.1 Cycle de vie d'un incident

La gestion des incidents de sécurité est un processus structuré visant à minimiser l'impact des événements adverses sur les systèmes d'information. Le NIST SP 800-61 **nist** définit un cycle de vie en quatre phases :

1. **Préparation** : mise en place des outils, des procédures et de l'équipe de réponse aux incidents avant qu'un événement ne survienne.
2. **Détection et analyse** : identification des signes d'intrusion ou d'anomalie via les systèmes de surveillance et corrélation des événements de sécurité.
3. **Confinement, éradication et rétablissement** : isolation des systèmes compromis, suppression des causes profondes et restauration des services dans un état de confiance connu.
4. **Activités post-incident** : analyse forensique, capitalisation des leçons apprises et mise à jour des procédures.

2.2.2 Indicateurs clés — TTD et TTR

La maturité d'un processus de gestion des incidents se mesure notamment par deux indicateurs : le TTD (Time To Detect) — délai entre l'occurrence d'un incident et sa détection — et le TTR (Time To Respond) — délai entre la détection et la mise en œuvre de contre-mesures efficaces. Des TTD et TTR faibles sont le signe d'une organisation de sécurité mature, dotée d'une surveillance automatisée efficace.

2.2.3 Conformité RGPD et notification des violations

L'article 33 du RGPD **rgpd** impose une obligation de notification de toute violation de données personnelles à l'autorité de contrôle compétente dans un délai de 72 heures suivant sa découverte. Cette exigence rend incontournable la mise en place de journaux d'audit immuables et de systèmes d'alerte automatisés capables de détecter et qualifier rapidement les incidents.

2.3 Supervision Réseau

2.3.1 Définition et enjeux

La supervision réseau désigne l'ensemble des pratiques et des outils permettant de surveiller en temps réel l'état, les performances et la sécurité des infrastructures informatiques. Elle constitue

le socle opérationnel de la détection des anomalies et des incidents de sécurité. Dans le contexte des architectures microservices, la supervision devient particulièrement complexe en raison de la multiplicité des composants à surveiller **microservices**.

2.3.2 Protocoles et technologies de supervision

- **SNMP (Simple Network Management Protocol)** : protocole standardisé permettant la collecte de métriques sur les équipements réseau (routeurs, switches, serveurs). La version 3 (SNMPv3) intègre des mécanismes d'authentification et de chiffrement.
- **Syslog (RFC 5424)** : protocole de transfert des journaux système vers un collecteur centralisé. Indispensable pour la corrélation d'événements et l'analyse forensique.
- **NetFlow / IPFIX** : protocoles d'analyse des flux réseau, permettant la détection d'anomalies de trafic (exfiltration de données, scans de ports).
- **Prometheus + Grafana** : solution open-source de supervision métrique, largement adoptée dans les architectures cloud-native et Docker/Kubernetes **docker**.

2.3.3 Supervision dans les architectures conteneurisées

Dans une architecture microservices conteneurisée, la supervision s'appuie sur des agents légers déployés à l'intérieur ou en périphérie des conteneurs. L'outil cAdvisor (Container Advisor) de Google permet la collecte des métriques de performance des conteneurs Docker (CPU, mémoire, réseau, I/O). Couplé à Prometheus pour le stockage et Grafana pour la visualisation, il forme la base d'une supervision efficace des environnements Docker **microservices**.

Bien que ces outils de supervision constituent des références pertinentes pour le suivi d'une infrastructure distribuée, ils n'ont pas été déployés dans le cadre du présent stage. Ils sont néanmoins présentés comme des pistes d'évolution intéressantes pour renforcer l'observabilité et la maintenance d'une future version du système.

2.4 Intelligence Artificielle Conversationnelle

Dans le cadre de ce projet, l'intelligence artificielle est mobilisée au service de l'expérience utilisateur, à travers un chatbot conversationnel et un agent de traduction multilingue intégrés directement à la plateforme web.

2.4.1 Traitement du Langage Naturel (NLP)

Le Traitement du Langage Naturel (Natural Language Processing, NLP) est la discipline de l'intelligence artificielle qui permet aux machines de comprendre, d'interpréter et de produire du langage

humain. Les avancées récentes dans les architectures Transformer **whisper** — notamment les Grands Modèles de Langage (LLM, Large Language Models) — ont rendu possible la construction d'assistants intelligents capables de comprendre le contexte conversationnel, de générer des réponses cohérentes et d'effectuer des tâches complexes telles que la traduction, la synthèse ou la reformulation de contenu.

Dans le contexte d'une plateforme métier, le NLP apporte une réponse directe aux enjeux d'accessibilité, d'efficacité opérationnelle et d'expérience utilisateur. Il réduit la friction entre l'utilisateur et le système en permettant des interactions en langage naturel plutôt que par navigation d'interfaces complexes.

2.4.2 Chatbots et assistants intelligents

Un chatbot intelligent est un agent logiciel capable d'engager une conversation avec un utilisateur en langage naturel, de maintenir le contexte au fil des échanges, et de fournir des réponses contextuellement pertinentes. Contrairement aux chatbots à base de règles (rule-based), les chatbots fondés sur des LLM génèrent dynamiquement leurs réponses, ce qui leur permet de traiter une grande variété de requêtes sans configuration préalable exhaustive.

Les bénéfices pour une plateforme métier sont significatifs :

- **Assistance utilisateur** : réponse instantanée aux questions fréquentes, guidage dans les fonctionnalités et réduction des tickets de support.
- **Automatisation** : prise en charge des tâches répétitives (recherche d'information, navigation guidée) libérant les opérateurs humains pour les tâches à valeur ajoutée.
- **Amélioration de l'expérience utilisateur (UX)** : interaction fluide et naturelle réduisant la courbe d'apprentissage de la plateforme.
- **Disponibilité** : service disponible 24h/24 sans intervention humaine.

2.4.3 Agent de traduction multilingue

Un agent de traduction est un composant logiciel capable de traduire automatiquement du contenu textuel d'une langue source vers une ou plusieurs langues cibles. Les LLM modernes offrent des performances de traduction compétitives pour les paires de langues courantes, avec l'avantage de pouvoir être déployés localement pour les applications soumises au RGPD **rgpd**.

Dans le contexte d'une plateforme destinée à une audience internationale, la traduction automatique apporte des bénéfices directs :

- **Accessibilité multilingue** : l'interface et les contenus peuvent être rendus accessibles dans la langue maternelle de chaque utilisateur sans multiplication des versions.
- **Communication internationale** : facilite les échanges entre utilisateurs de langues différentes

au sein de la même plateforme.

- **Conformité RGPD** : un déploiement local élimine la transmission de données à des services tiers, conformément aux exigences du Règlement Général sur la Protection des Données.

2.5 SOC et SIEM — Perspectives de sécurité opérationnelle

Note préliminaire : Les technologies SOC et SIEM présentées dans cette section n'ont pas été déployées dans le cadre du présent projet. Elles ont été étudiées dans une démarche de veille technologique et sont présentées comme des perspectives d'évolution sérieuses pour une version future de la plateforme.

2.5.1 Security Operations Center (SOC)

Un SOC (Security Operations Center) est une unité organisationnelle centralisée dédiée à la surveillance continue, à la détection et à la réponse aux incidents de sécurité. Il opère 24h/24 en traitant les alertes provenant des pare-feux, IDS/IPS, SIEM et journaux système pour qualifier, prioriser et coordonner la réponse aux incidents. L'évolution récente des SOC va vers une automatisation croissante via les plateformes SOAR (Security Orchestration, Automation and Response), intégrant l'IA pour réduire le TTD et concentrer les analystes sur les menaces à haute valeur ajoutée **nist**.

Dans le contexte du présent projet, un SOC constituerait une évolution pertinente pour assurer la surveillance continue de la plateforme événementielle en production, notamment pour la corrélation des journaux d'authentification et la détection des abus de l'API chatbot.

2.5.2 SIEM — Security Information and Event Management

Un SIEM agrège, normalise et corrèle les journaux d'événements de l'ensemble des composants du système d'information, remplissant deux fonctions complémentaires : la gestion des informations de sécurité (SIM) et la gestion des événements en temps réel (SEM) **nist**.

Le tableau 2.2 présente une synthèse comparative des principales solutions disponibles, dans une logique de veille technologique orientée vers la perspective d'évolution de la plateforme.

Solution	Caractéristiques principales	Licence
Splunk	Maturité industrielle, richesse des connecteurs, haute volumétrie	Propriétaire
IBM QRadar	Corrélation avancée, intégration écosystème IBM Security	Propriétaire

Solution	Caractéristiques principales	Licence
Elastic SIEM (ELK)	Flexibilité, scalabilité, large communauté open-source	Open-source
Wazuh	HIDS + SIEM, RGPD-friendly, léger, adapté aux PME	Open-source

TABLEAU 2.2 : Comparatif des solutions SIEM — veille technologique

Parmi ces solutions, Wazuh apparaît comme la perspective d’évolution la plus adaptée : open-source, RGPD natif, léger et cohérent avec les contraintes d’une infrastructure académique. Son intégration future permettrait de centraliser les journaux d’authentification JWT, les alertes de rate limiting et les accès RBAC dans un tableau de bord unifié.

Conclusion

Cet état de l’art a permis de dresser un panorama ciblé des domaines qui fondent directement les choix techniques du projet. Les concepts de la triade CIA, la modélisation des menaces par STRIDE, les protocoles TLS 1.3 pour les communications sécurisées, les architectures de chatbot IA basées sur les LLM et les agents de traduction multilingues, ainsi que les exigences du RGPD pour la protection des données personnelles constituent le socle théorique sur lequel repose l’architecture développée.

L’intelligence artificielle conversationnelle — chatbots contextuels et agents de traduction — se confirme comme le vecteur d’innovation principal de la plateforme, apportant une valeur ajoutée directe à l’expérience utilisateur tout en restant parfaitement compatible avec les exigences de souveraineté des données du RGPD grâce au déploiement local.

La supervision réseau avancée ainsi que les architectures SOC et SIEM ont été présentées comme des références de l’état de l’art et des perspectives d’évolution sérieuses, mais ne font pas partie du périmètre de réalisation du présent stage. Cette distinction garantit la cohérence et la crédibilité de l’analyse au regard du travail effectivement réalisé.

Le chapitre suivant traduit ces connaissances en spécifications concrètes, en définissant les besoins fonctionnels et non fonctionnels du système et en justifiant les choix technologiques retenus à la lumière des comparatifs présentés ici.

SPÉCIFICATION DES BESOINS

Plan

1	Concepts Fondamentaux de la Cybersécurité	11
2	Gestion des Incidents de Sécurité	13
3	Supervision Réseau	13
4	Intelligence Artificielle Conversationnelle	14
5	SOC et SIEM — Perspectives de sécurité opérationnelle	16

Introduction

Ce chapitre formalise l'ensemble des exigences du système à partir des objectifs définis au chapitre 1 et des concepts identifiés dans l'état de l'art. Il identifie les acteurs, spécifie les besoins fonctionnels au travers de diagrammes de cas d'utilisation UML, définit les exigences non fonctionnelles, et présente les études comparatives qui ont guidé les choix technologiques du projet.

Les exigences présentées ci-après traduisent les besoins métier identifiés pour la plateforme événementielle, tout en intégrant les contraintes de sécurité, de conformité et d'expérience utilisateur propres au contexte du projet. Pour chaque exigence, le lien avec une fonctionnalité concrète est explicité afin de garantir la traçabilité entre les besoins et l'architecture définie au chapitre suivant.

3.1 Identification des Acteurs

Le tableau 3.1 présente les cinq acteurs identifiés, leur nature et leur rôle respectif au sein du système.

Acteur	Type	Rôle dans le système
Organisateur	Humain	Crée et gère les événements, configure le template dédié, invite les participants et supervise le bon déroulement de la session.
Participant	Humain	Rejoint les événements via un lien d'invitation sécurisé, interagit avec les autres participants et consulte les sous-titres générés par l'IA.
Administrateur	Humain	Administre l'ensemble de la plateforme : gestion des comptes utilisateurs, configuration système, attribution des rôles, surveillance des journaux d'activité et maintenance.
Agent IA (Chatbot / Traduction)	Système	Assiste les utilisateurs via le chatbot conversationnel, effectue la traduction automatique multilingue et fournit des réponses contextuelles en langage naturel.
Odoo (ERP)	Système	Synchronise les données relatives aux événements et aux comptes utilisateurs entre la plateforme événementielle et le progiciel de gestion intégré.

Acteur	Type	Rôle dans le système
--------	------	----------------------

TABLEAU 3.1 : Identification des acteurs du système

3.2 Spécification des Besoins Fonctionnels

La spécification des besoins fonctionnels traduit les attentes des parties prenantes en un ensemble structuré de cas d'utilisation, modélisés selon la notation UML. Cinq diagrammes de cas d'utilisation ont été élaborés, correspondant chacun à un module fonctionnel majeur de la plateforme.

3.2.1 Vue d'ensemble du système

La vue d'ensemble offre une représentation macroscopique du système, organisant les cas d'utilisation en cinq packages thématiques.

ID	Nom	Acteur(s)	Type
UC_01	S'authentifier (MFA)	Tous	Normal
UC_02	Gérer son profil et ses données	Utilisateur	Normal
UC_03	Interagir avec le chatbot IA	Utilisateur	Normal
UC_04	Traduire du contenu	Utilisateur	Normal
UC_05	Consulter l'assistance IA	Utilisateur	Normal
UC_06	Gérer les utilisateurs et rôles	Administrateur	Normal
UC_07	Administrer la plateforme	Administrateur	Normal
UC_08	Gérer la conformité RGPD	Administrateur	Normal

TABLEAU 3.2 : Cas d'utilisation — Vue d'ensemble du système

Les cinq packages fonctionnels sont : Authentification & Sécurité (connexion, MFA, gestion des sessions), Chatbot IA (assistance conversationnelle, NLP, réponses contextuelles), Traduction Multilingue (agent de traduction, sélection de langue, affichage), Administration (gestion des comptes, des rôles, des permissions) et Conformité & Données (RGPD, consentement, droit à l'oubli).

Le tableau 3.3 présente la correspondance entre les besoins métier identifiés, les fonctionnalités associées et les solutions techniques retenues.

Besoin métier	Fonctionnalité	Solution technique
Contrôler l'accès à la plateforme	Authentification sécurisée	MFA (TOTP RFC 6238) + JWT RS256

Besoin métier	Fonctionnalité	Solution technique
Gérer les droits et permissions	Contrôle d'accès granulaire	RBAC (5 rôles)
Assister les utilisateurs en temps réel	Chatbot conversationnel IA	LLM + API NLP
Permettre l'accès multilingue	Traduction automatique	Agent LLM local + API de traduction
Protéger les données personnelles	Conformité RGPD	Privacy by Design, export/suppression
Sécuriser les échanges réseau	Chiffrement des communications	TLS 1.3, AES-256
Valider les données utilisateur	Filtrage et validation des entrées	OWASP, sanitisation, middleware
Administrer la plateforme	Dashboard d'administration	Interface admin + API REST

TABLEAU 3.3 : Correspondance Besoins — Fonctionnalités — Solutions techniques

3.2.2 Gestion des Événements et Authentification

ID	Nom	Acteur(s)	Type
UC_A01	S'inscrire	Organisateur, Participant	Normal
UC_A02	Se connecter	Tous	Normal
UC_A03	Activer le MFA	Tous	Include
UC_A04	Réinitialiser le mot de passe	Tous	Normal
UC_A05	Gérer les comptes	Administrateur	Normal
UC_E01	Créer un événement	Organisateur	Normal
UC_E02	Définir la date et l'heure	Organisateur	Include
UC_E03	Configurer le template	Organisateur	Normal
UC_E04	Inviter des participants	Organisateur	Normal
UC_E05	Annuler ou reporter	Organisateur	Extend
UC_O01	Synchroniser les événements	Odoo (ERP)	Normal

ID	Nom	Acteur(s)	Type
UC_O02	Synchroniser les comptes	Odoo (ERP)	Normal

TABLEAU 3.4 : Cas d'utilisation — Gestion des Événements et Authentification

3.2.3 Déroulement des Réunions Virtuelles

ID	Nom	Acteur(s)	Type
UC_M01	Rejoindre l'événement	Participant, Organisateur	Normal
UC_M02	Se connecter	Participant, Organisateur	Include
UC_M03	Quitter la session	Participant	Normal
UC_M04	Activer/désactiver caméra	Participant	Normal
UC_M05	Activer/désactiver micro	Participant	Normal
UC_M06	Partager l'écran	Participant, Organisateur	Extend
UC_M07	Utiliser le chat	Participant	Normal
UC_M08	Enregistrer la session	Organisateur	Extend
UC_M09	Lever / baisser la main	Participant	Normal
UC_M10	Accorder / révoquer la parole	Organisateur	Include
UC_M11	Éjecter un participant	Organisateur	Normal
UC_M12	Créer des breakout rooms	Organisateur	Extend

TABLEAU 3.5 : Cas d'utilisation — Déroulement des Réunions Virtuelles

3.2.4 Intelligence Artificielle — Chatbot et Traduction

ID	Nom	Acteur(s)	Type
UC_I01	Envoyer un message au chatbot	Utilisateur	Normal
UC_I02	Recevoir une réponse contextuelle	Agent IA	Include
UC_I03	Maintenir le contexte conversationnel	Agent IA	Include
UC_I04	Sélectionner la langue cible	Participant	Normal

ID	Nom	Acteur(s)	Type
UC_I05	Soumettre un texte à traduire	Participant	Normal
UC_I06	Obtenir la traduction	Agent IA	Include
UC_I07	Afficher le résultat traduit	Participant	Include
UC_I08	Consulter l'historique de conversation	Utilisateur	Normal

TABLEAU 3.6 : Cas d'utilisation — Intelligence Artificielle : Chatbot et Traduction

3.2.5 Gestion RGPD et Administration Système

ID	Nom	Acteur(s)	Type
UC_R01	Consulter l'historique des sessions	Participant, Organisateur	Normal
UC_R02	Consulter les enregistrements	Participant, Organisateur	Normal
UC_R03	Lire la politique de confidentialité	Tous	Normal
UC_R04	Gérer les consentements	Participant	Include
UC_R05	Télécharger ses données personnelles	Participant	Include
UC_R06	Exercer le droit à l'oubli	Participant	Extend
UC_R07	Supprimer ses données	Participant	Include
UC_R08	Auditer les accès	Administrateur	Include
UC_R09	Chiffrer les données (au repos)	Système	Normal
UC_R10	Générer un rapport de conformité RGPD	Administrateur	Extend

TABLEAU 3.7 : Cas d'utilisation — Gestion RGPD et Données Personnelles (UC_R01 à UC_R10)

3.3 Spécification des Besoins Non Fonctionnels

Les besoins non fonctionnels définissent les qualités globales que le système doit présenter, indépendamment des fonctionnalités spécifiques qu'il offre.

Catégorie	Exigence principale	Niveau attendu
Sécurité	Chiffrement TLS/SRTP, MFA, RBAC, modèle STRIDE appliqué	Critique
Performance	Latence IA < 2 s pour la transcription, 500 participants simultanés	Élevé
Disponibilité	Tolérance aux pannes, reprise après incident	99,9%
Conformité	RGPD art. 5, 15, 17, 20, 25 — droit à l'oubli, consentement explicite	Réglementaire
Scalabilité	Architecture microservices, conteneurisation Docker, OVHcloud	Horizontal
Accessibilité	Sous-titres multilingues temps réel, compatibilité navigateurs W3C	Standard W3C

TABLEAU 3.8 : Synthèse des besoins non fonctionnels

3.4 Études Comparatives des Outils Retenus

3.4.1 Plateformes de visioconférence

Le tableau 3.9 compare les principales solutions de visioconférence selon les critères sécurité, souveraineté des données, personnalisation et compatibilité RGPD.

Solution	Chiffrement	Données UE	Personnalisation	RGPD
Zoom	E2E optionnel	Serveurs USA	Limitée	Partiel
Microsoft Teams	TLS / E2E	Azure Europe	Modérée	Oui (DPA)
Google Meet	TLS	GCP (mondial)	Faible	Partiel
Jitsi Meet	TLS 1.3 + SRTP	Autohébergé	Totale	Oui (local)

TABLEAU 3.9 : Comparatif des solutions de visioconférence

Choix retenu : Jitsi Meet. Son auto-hébergement garantit la souveraineté totale des données, son chiffrement natif SRTP est optimal pour WebRTC, et sa personnalisation complète permet l'intégration

des tokens JWT pour le contrôle d'accès **webrtc**.

3.4.2 Progiciels ERP

Solution	Modules événementiels	API REST	Licence
SAP Business One	Oui (module Events)	Oui (OData)	Propriétaire (coûteux)
Microsoft Dynamics 365	Oui (Event Management)	Oui (REST)	Propriétaire (abonnement)
Odoo 17	Oui (modules natifs + custom)	Oui (JSON-RPC, REST)	Open-source (LGPL)

TABLEAU 3.10 : Comparatif des solutions ERP

Choix retenu : Odoo 17. Son architecture modulaire permet le développement du module personnalisé `ai_healthcare_event` pour gérer le cycle complet des événements (inscriptions, emails JWT, RGPD), sans coût de licence.

3.4.3 Solutions de chatbot et d'IA conversationnelle

Solution	Compréhension contextuelle	Déploiement local	RGPD	Coût
ChatGPT API (OpenAI)	Excellente	Non (cloud USA)	Risque transfert données	Payant à l'usage
Dialogflow (Google)	Bonne	Non (cloud)	Partiel	Freemium
Rasa (open-source)	Bonne (règles + ML)	Oui	Oui	Gratuit (self-hosted)
LLM local (API NLP)	Excellente	Oui	Oui (natif)	Gratuit (self-hosted)

TABLEAU 3.11 : Comparatif des solutions de chatbot / IA conversationnelle

Choix retenu : LLM déployé localement via API NLP. Seule solution combinant compréhension contextuelle avancée, déploiement local garantissant la conformité RGPD, et indépendance totale

vis-à-vis des API tierces payantes **whisper**.

3.4.4 Fournisseurs d'infrastructure cloud

Fournisseur	Localisation données	Conformité RGPD	Coûts
AWS	Mondial (USA majoritaire)	Clauses DPA disponibles	Egress fees élevés
Microsoft Azure	Europe possible	Certifications multiples	Modèle complexe
Google Cloud Platform	Mondial	Clauses DPA disponibles	Egress fees importants
OVHcloud	France (Roubaix, Strasbourg)	Natif, DPA contractuel	Prévisible, sans egress fees

TABLEAU 3.12 : Comparatif des fournisseurs d'infrastructure cloud

Choix retenu : OVHcloud. Sa souveraineté européenne est un critère décisif pour la conformité RGPD **rgpd**, sa tarification prévisible facilite la maîtrise des coûts et ses datacenters français éliminent toute incertitude sur la localisation des données personnelles.

3.5 Justification Globale des Choix Techniques

L'ensemble des choix technologiques retenus forme un écosystème cohérent répondant aux cinq axes stratégiques du projet :

Axe	Technologie retenue	Justification principale
Sécurité des communications	TLS 1.3 + SRTP	Standard IETF, chiffrement 1-RTT, protection flux WebRTC
Authentification	MFA (TOTP RFC 6238) + JWT	Résistance au phishing, stateless, standard microservices
Visioconférence	Jitsi Meet	Auto-hébergé, SRTP natif, JWT intégré, open-source
ERP / Gestion	Odoo 17	Modules personnalisables, API REST, open-source, RGPD

Axe	Technologie retenue	Justification principale
Chatbot IA / Traduction	LLM local (API NLP)	Contextuel, local, RGPD-friendly, indépendant des API tierces whisper
Conteneurisation	Docker + Docker Compose	Portabilité, isolation, CI/CD, standard industriel docker
Infrastructure Cloud	OVHcloud	Souveraineté UE, conformité RGPD native, coûts prévisibles
Normes de sécurité	NIST CSF 2.0 + STRIDE	Référentiels reconnus pour la sécurité by design niststride

TABLEAU 3.13 : Synthèse de la justification des choix techniques

Conclusion

Ce chapitre a établi la spécification complète du système, depuis l'identification des acteurs jusqu'à la justification des choix technologiques. Les besoins fonctionnels formalisés en cas d'utilisation UML et les six catégories d'exigences non fonctionnelles constituent le contrat de référence pour la conception détaillée présentée au chapitre suivant. Les études comparatives ont démontré la pertinence et la cohérence de l'écosystème technologique retenu — Jitsi, Odoo, LLM local (Chatbot IA), Docker, OVHcloud — au regard des contraintes sécuritaires, réglementaires et de performance du projet. Le chatbot IA, fondé sur un LLM déployé localement, constitue l'innovation principale différenciant la plateforme des solutions concurrentes.

CONCEPTION DE L'ARCHITECTURE

Plan

1	Identification des Acteurs	19
2	Spécification des Besoins Fonctionnels	20
3	Spécification des Besoins Non Fonctionnels	23
4	Études Comparatives des Outils Retenus	24
5	Justification Globale des Choix Techniques	26

Introduction

Le chapitre précédent a permis d'établir un référentiel complet des besoins du système, à travers l'identification des acteurs, la spécification des cas d'utilisation et la définition des exigences non fonctionnelles en matière de sécurité, de performance et de conformité réglementaire. Fort de ce socle analytique, le présent chapitre expose les choix architecturaux retenus pour répondre à ces exigences et décrit la structure interne du système à différents niveaux d'abstraction. La section 4.2 présente l'architecture globale en couches et justifie les technologies retenues. La section 4.3 détaille la modélisation des composants logiciels au travers des diagrammes de classes et de séquence. La section 4.4 approfondit les mécanismes de sécurité intégrés à la conception. Enfin, la section 4.5 décrit l'architecture de déploiement, depuis la conteneurisation jusqu'au pipeline d'intégration et de déploiement continus.

4.1 Architecture Globale du Système

4.1.1 Vue en couches

La conception d'un système de visioconférence sécurisé intégrant des services d'intelligence artificielle en temps réel nécessite une organisation architecturale rigoureuse, capable de séparer les responsabilités tout en garantissant la fluidité des échanges entre composants. L'architecture retenue pour ce projet repose sur un modèle en sept couches distinctes, chacune encapsulant un ensemble cohérent de fonctionnalités et d'interactions. Ce découpage en couches favorise la maintenabilité, la testabilité indépendante de chaque niveau et la scalabilité horizontale ciblée des composants les plus sollicités.

La **première couche**, dite Couche Client, constitue le point d'entrée de tout utilisateur dans le système : elle expose l'interface web frontend à travers laquelle organisateurs et participants accèdent à la plateforme depuis un navigateur standard, sans installation logicielle préalable. La **deuxième couche**, dite Couche Accès & Sécurité, forme le bouclier périmétrique du système : elle regroupe le répartiteur de charge (Load Balancer), le mandataire inverse (Reverse Proxy), le pare-feu applicatif web (WAF) et le sous-système d'authentification multi-facteurs (MFA) basé sur le protocole OAuth 2.0 ; aucune requête ne peut atteindre les couches internes sans avoir été filtrée et authentifiée à ce niveau. La **troisième couche**, dite Couche Traitement IA, héberge les deux services d'intelligence artificielle : le chatbot conversationnel fondé sur un Large Language Model (LLM), qui assiste les utilisateurs en langage naturel depuis toutes les pages de la plateforme, et l'agent de traduction multilingue déployé localement pour garantir la confidentialité des données conformément

au RGPD. La **quatrième couche**, dite Couche Communication Temps Réel, gère la signalisation et le routage des flux multimédias : le Video Bridge agrège les flux vidéo des participants, Jicofo assure la gestion des conférences via le protocole XMPP, et Prosody joue le rôle de serveur de signalisation. La **cinquième couche**, dite Couche Application, orchestre la logique métier : l'Odoo Backend API gère les événements, les utilisateurs et les données organisationnelles, tandis que le Meeting Management Service coordonne le cycle de vie des sessions. La **sixième couche**, dite Couche Infrastructure, assure la fondation opérationnelle du système : l'ensemble des services est conteneurisé via Docker, déployé sur l'infrastructure cloud OVHcloud, et soumis à un pipeline CI/CD automatisé couplé à un système de supervision et de journalisation (Monitoring & Logging). Enfin, la **septième couche**, dite Couche Données, gère la persistance et la protection des informations : la base de données relationnelle et le stockage sécurisé des fichiers sont protégés par les contrôles de sécurité transversaux — RBAC, TLS et journaux d'audit — qui s'appliquent à l'ensemble de la pile.

4.1.2 Justification des choix architecturaux

Chaque technologie retenue dans cette architecture a fait l'objet d'une évaluation comparative tenant compte des critères de sécurité, de conformité réglementaire, de maturité de l'écosystème et d'adéquation aux contraintes spécifiques du projet. Le tableau 4.1 synthétise les principaux choix technologiques et leur justification.

Composant	Technologie retenue	Justification
Conteneurisation	Docker	Portabilité entre environnements, isolation des services, déploiements reproductibles et rollback facilité.
Infrastructure Cloud	OVHcloud	Souveraineté européenne des données, conformité RGPD garantie contractuellement, datacenter localisé en France.
Gestion ERP	Odoo	Solution open-source, architecture modulaire, API REST native et communauté active facilitant les intégrations.

Composant	Technologie retenue	Justification
Chatbot IA	LLM (API NLP)	Compréhension contextuelle du langage naturel, génération de réponses pertinentes, intégration native dans l'interface web.
Agent de traduction	LLM local	Traduction multilingue précise, déploiement local garantissant la conformité RGPD, indépendance des API tierces.
Chiffrement réseau	TLS 1.3	Version la plus récente du protocole, réduction de la latence de négociation (0-RTT), suppression des algorithmes obsolètes.
Authentification	MFA + JWT	Double facteur d'authentification associé à des tokens stateless signés, réduisant la surface d'attaque sur les sessions.
Contrôle d'accès	RBAC	Modèle éprouvé permettant une granularité fine des permissions selon le profil de chaque utilisateur.

TABLEAU 4.1 : Justification des choix technologiques

L'ensemble de ces choix technologiques forme un écosystème cohérent dans lequel chaque composant joue un rôle précis et complémentaire. La priorité accordée aux solutions open-source — Whisper, Odoo, Docker — réduit la dépendance à des éditeurs propriétaires et garantit la transparence du code, un critère particulièrement important en contexte de cybersécurité. Par ailleurs, l'adoption de standards ouverts tels que WebRTC, TLS 1.3 et JWT assure l'interopérabilité du système avec l'écosystème web existant, tout en bénéficiant de la rigueur des processus de standardisation internationaux.

Infrastructure Cloud — OVHcloud vs. AWS/Azure/GCP. Bien que les géants Amazon Web Services, Microsoft Azure et Google Cloud Platform offrent des services plus étendus, OVHcloud a été privilégié pour des raisons stratégiques déterminantes. Sa politique de souveraineté des données et son implantation exclusivement européenne (datacenters en France) répondent directement aux

exigences du RGPD **rgpd**, un critère non fonctionnel critique. Son modèle de tarification prédictible, sans frais excessifs de sortie de données (egress fees), permet une meilleure maîtrise des coûts d'infrastructure à mesure que la plateforme monte en charge.

Conteneurisation — Docker vs. Kubernetes. Docker Compose a été retenu pour la phase initiale de développement et de déploiement pour sa simplicité de configuration et sa faible courbe d'apprentissage, offrant un rapport performance/complexité optimal pour un système à l'échelle d'un PFE. Kubernetes, bien que l'orchestrateur de référence pour les architectures à grande échelle **docker**, introduit une complexité opérationnelle significative qui dépasse les besoins actuels. Une migration vers Kubernetes est néanmoins envisagée comme perspective d'évolution pour une montée en charge de la plateforme en production.

Authentification sécurisée — MFA et JWT. L'algorithme RS256 utilisé pour la signature des tokens JWT offre un équilibre optimal entre sécurité cryptographique asymétrique et performance computationnelle. Couplé au double facteur TOTP, il constitue une défense robuste contre les compromissions de comptes, alignée avec les recommandations du NIST **nist**.

4.2 Modélisation Détaillée des Composants

4.2.1 Diagramme de classes

Le diagramme de classes constitue l'outil central de la modélisation orientée objet. Il représente la structure statique du système en identifiant les entités logicielles — appelées classes — leurs attributs, leurs opérations et les relations qui les unissent. Dans le cadre d'une architecture en microservices telle que celle adoptée pour ce projet, le diagramme de classes permet de formaliser les contrats d'interface entre les différents services, de clarifier les responsabilités de chaque composant et de guider l'implémentation de manière cohérente et maintenable.

Le système est modélisé par neuf classes principales dont les interactions reflètent le flux de données décrit dans les cas d'utilisation du chapitre précédent. La classe **User** est l'entité centrale autour de laquelle s'organisent toutes les interactions : elle est associée à **AuthService**, qui gère les mécanismes d'authentification et de vérification MFA, et à **SecurityManager**, qui assure de manière transversale le chiffrement des données, les vérifications d'autorisation et la journalisation des activités. La classe **Frontend** orchestre l'interface utilisateur et entretient des associations directes avec **OdooBackend** — pour la gestion des événements et des utilisateurs — , **STTService** — pour la transcription audio — et **JitsiBridge** — pour la gestion des flux multimédias. La classe **STTService** est elle-même liée par association à **TranslationService**, formant ainsi le pipeline IA de transcription-traduction. Enfin, la classe **Meeting** est composée au sein de **OdooBackend**, traduisant le fait que le cycle de vie d'un

événement est intégralement géré par le module ERP.

Le tableau 4.2 détaille les responsabilités et les méthodes principales de chacune des neuf classes du système.

Classe	Responsabilité	Méthodes principales
AuthService	Gestion de l'authentification des utilisateurs	<code>login()</code> , <code>verifyMFA()</code>
User	Entité utilisateur centrale du système	<code>authenticate()</code> , <code>joinMeeting()</code>
Frontend	Interface utilisateur et orchestration des flux	<code>startSession()</code> , <code>captureAudio()</code> , <code>displaySubtitles()</code>
SecurityManager	Sécurité transversale (chiffrement, accès, audit)	<code>encrypt()</code> , <code>authorize()</code> , <code>logActivity()</code>
OdooBackend	Intégration ERP et persistance des événements	<code>createMeeting()</code> , <code>manageUsers()</code> , <code>storeData()</code>
STTService	Transcription automatique du flux audio	<code>transcribe(audio)</code>
TranslationService	Traduction multilingue du texte transcrit	<code>translate(text)</code>
JitsiBridge	Gestion et routage des flux vidéo WebRTC	<code>handleStream()</code>
Meeting	Entité représentant un événement en ligne	<code>start()</code> , <code>end()</code>

TABLEAU 4.2 : Description des classes du système

4.2.2 Diagramme de séquence

Le diagramme de séquence modélise le comportement dynamique du système en représentant les interactions entre acteurs et composants dans l'ordre chronologique de leur exécution. Le scénario retenu correspond au flux nominal complet d'une interaction utilisateur avec le chatbot IA : depuis la connexion initiale jusqu'à l'obtention d'une réponse contextuelle. Ce scénario implique cinq entités —

l'utilisateur (User), le Frontend, le Load Balancer / Reverse Proxy, le service d'authentification (Auth Service) et le service chatbot (Chatbot Service / LLM) — et se déroule en trois phases distinctes.

La **Phase 1** (étapes 1 à 4) couvre l'authentification sécurisée : l'utilisateur soumet ses identifiants au Frontend, qui les transmet via HTTPS au Load Balancer. Celui-ci route la requête vers l'Auth Service, qui vérifie le mot de passe (bcrypt) puis le second facteur d'authentification (TOTP RFC 6238) ; un token JWT RS256 valide 15 minutes est généré et renvoyé au Frontend.

La **Phase 2** (étapes 5 à 8) couvre l'envoi d'un message et la validation sécurisée : l'utilisateur saisit sa question dans le widget chatbot ; le Frontend envoie la requête POST `/api/chat/message` avec le token JWT en en-tête. Le middleware du Chatbot Service vérifie la signature JWT, extrait le rôle RBAC, sanitise l'entrée (filtrage XSS, rate limiting) et construit le prompt enrichi avec l'historique conversationnel et le contexte utilisateur.

La **Phase 3** (étapes 9 à 11) couvre la génération et l'affichage de la réponse : le Chatbot Service appelle le moteur LLM avec le prompt enrichi ; le LLM génère une réponse contextuelle et pertinente ; la réponse JSON est retournée au Frontend, qui l'affiche dans le fil de conversation avec horodatage et rendu Markdown. L'ensemble des communications inter-services est protégé par TLS 1.3.

Le flux en onze étapes est détaillé ci-après :

1. **Connexion utilisateur** : l'utilisateur soumet ses identifiants depuis le Frontend.
2. **Requête HTTPS** : le Frontend transmet la requête au Load Balancer via TLS 1.3.
3. **Authentification MFA** : l'Auth Service vérifie le mot de passe (bcrypt) puis le code TOTP (second facteur).
4. **Émission du token JWT** : le token RS256 (15 min) est retourné au Frontend et stocké en session.
5. **Saisie du message chatbot** : l'utilisateur entre sa question dans le widget intégré à la plateforme.
6. **Envoi POST `/api/chat/message`** : le Frontend transmet le message avec le token JWT en en-tête Authorization : Bearer.
7. **Validation JWT et sanitisation** : le middleware vérifie la signature, extrait le rôle RBAC, sanitise l'entrée et applique le rate limiting.
8. **Construction du prompt enrichi** : le service injecte l'historique des N derniers tours et le contexte utilisateur dans le prompt système LLM.
9. **Appel du moteur LLM** : le Chatbot Service soumet le prompt au modèle de langage.
10. **Génération de la réponse** : le LLM génère une réponse contextuelle et la retourne au service en JSON.

11. **Affichage dans l'interface** : le Frontend affiche la réponse dans le fil de conversation avec rendu Markdown et horodatage.

4.3 Architecture de Sécurité

Chaque mécanisme de sécurité retenu dans l'architecture répond à une menace ou à un besoin identifié lors de l'analyse du système. Cette approche permet d'assurer une cohérence entre l'expression des exigences, la conception technique et la validation du projet. Le tableau 4.3 présente la correspondance entre les principales menaces modélisées et les contremesures architecturales qui leur sont associées.

Catégorie STRIDE	Menace visée	Mesure de protection retenue
Spoofing (Usurpation)	Usurpation d'identité, faux utilisateur	Authentification MFA (TOTP RFC 6238) + JWT signé RS256
Tampering (Altération)	Modification des données en transit	TLS 1.3 (RFC 8446), SRTP, hachage SHA-256
Repudiation	Déni d'une action effectuée	Journaux d'audit immuables + horodatage systématique
Information Disclosure (Divulgaration)	Interception des flux, fuite de données	Chiffrement AES-256 au repos, TLS 1.3 en transit
Denial of Service (DoS)	Saturation du service, indisponibilité	WAF, Load Balancer, architecture microservices résiliente
Elevation of Privilege	Accès non autorisé à des ressources restreintes	RBAC à cinq niveaux + validation systématique des tokens JWT
Non-conformité RGPD	Traitement illicite de données personnelles	RGPD by Design (art. 5, 15, 17, 20, 25), droit à l'oubli

TABLEAU 4.3 : Correspondance menaces / mesures de protection (modèle STRIDE)

4.3.1 Chiffrement des communications

L'ensemble du trafic applicatif entre les clients et les serveurs est chiffré à l'aide du protocole TLS 1.3 (Transport Layer Security, version 1.3). Cette version, standardisée par l'IETF en 2018 via la RFC 8446, représente une évolution majeure par rapport à ses prédécesseurs : elle supprime les suites cryptographiques obsolètes (RC4, SHA-1, DES), réduit le délai de négociation à un seul aller-retour réseau (1-RTT handshake) et introduit la reprise de session à latence nulle (0-RTT) pour les connexions répétées. L'intégration de TLS 1.3 au niveau du Reverse Proxy Nginx garantit que toute communication entre le navigateur de l'utilisateur et la plateforme est protégée contre les écoutes passives et les attaques par interposition (man-in-the-middle).

Le protocole SRTP (Secure Real-time Transport Protocol) complète TLS 1.3 pour la protection des flux audio et vidéo en temps réel acheminés via WebRTC. Contrairement à TLS, qui est conçu pour les flux TCP orientés connexion, SRTP opère au-dessus d'UDP et est spécifiquement optimisé pour les contraintes des communications multimédias en temps réel : faible surcoût cryptographique, tolérance aux pertes de paquets et faible latence de chiffrement. SRTP assure la confidentialité, l'intégrité et la protection contre le rejeu des flux multimédias. Ces deux protocoles sont donc complémentaires et non redondants : TLS 1.3 protège la signalisation et les échanges applicatifs (authentification, transcription, traduction), tandis que SRTP protège les flux multimédias temps réel qui empruntent des canaux UDP distincts.

4.3.2 Authentification multi-facteurs (MFA)

L'authentification multi-facteurs constitue l'un des mécanismes de protection les plus efficaces contre les attaques par compromission de credentials. Le flux MFA implémenté dans la plateforme se déroule en deux étapes séquentielles et obligatoires. La première étape repose sur la vérification des identifiants classiques : l'utilisateur saisit son adresse électronique et son mot de passe, lesquels sont transmis de manière chiffrée à l'Auth Service. Si les identifiants sont valides, la deuxième étape est déclenchée : l'utilisateur reçoit un code OTP (One-Time Password) à usage unique, généré selon le standard TOTP (RFC 6238) et valable pendant une fenêtre temporelle de trente secondes. À l'issue de la validation de ce second facteur, l'Auth Service émet un token JWT (JSON Web Token) signé cryptographiquement à l'aide de l'algorithme RS256. Ce token a une durée de validité configurable — typiquement quinze minutes pour le token d'accès — et est accompagné d'un refresh token de longue durée permettant de renouveler la session sans réauthentification complète.

4.3.3 Contrôle d'accès basé sur les rôles (RBAC)

Le modèle de contrôle d'accès basé sur les rôles (Role-Based Access Control, RBAC) est implémenté de manière transversale dans l'ensemble de la plateforme. Cinq rôles distincts ont été définis, correspondant aux acteurs identifiés lors de la phase d'analyse. Le tableau 4.4 présente les permissions accordées et les ressources accessibles pour chacun de ces rôles.

Rôle	Permissions accordées	Ressources accessibles
Participant	Lecture, participation aux sessions	Sessions en cours, sous-titres, historique personnel
Organisateur	Lecture, écriture, gestion de session	Événements, listes de participants, enregistrements
Administrateur	Accès total en lecture et écriture	Système complet, journaux d'audit, paramètres de configuration
Agent IA	Lecture des flux audio, écriture des transcriptions	Flux temps réel entrants, stockage des transcriptions
Odoo ERP	Synchronisation en lecture et écriture	Données des événements et comptes utilisateurs

TABLEAU 4.4 : Matrice des rôles et permissions (RBAC)

L'application du modèle RBAC est guidée par le principe du moindre privilège (principle of least privilege) : chaque entité — humaine ou systématique — ne se voit accorder que les permissions strictement nécessaires à l'accomplissement de ses fonctions.

4.3.4 Conformité RGPD dans la conception

La conformité au Règlement Général sur la Protection des Données (RGPD) est intégrée dès la phase de conception, selon l'approche Privacy by Design préconisée par l'article 25 du règlement. Sur le plan des mesures techniques, les données personnelles stockées en base de données font l'objet d'un chiffrement au repos (encryption at rest) à l'aide de l'algorithme AES-256, tandis que les identifiants directs (noms, adresses électroniques) sont soumis à une pseudonymisation dans les journaux d'audit et les exports de données analytiques. Des durées de rétention définies et automatisées sont appliquées à chaque catégorie de données : les enregistrements vidéo sont supprimés au bout de quatre-vingt-dix jours par défaut, les transcriptions sont conservées trente jours, et les journaux d'accès sont archivés pour une durée d'un an conformément aux recommandations de la CNIL.

4.3.5 Analyse des menaces — Modèle STRIDE

Une analyse des menaces basée sur le modèle STRIDE **stride** a été menée pour identifier et mitiger les risques potentiels à chaque niveau de l'architecture :

- **Usurpation d'identité (Spoofing)** : mitigée par l'authentification multi-facteurs (MFA) et l'utilisation de JWT signés RS256 pour la gestion des sessions.
- **Altération des données (Tampering)** : prévenue par le chiffrement des communications (TLS 1.3/SRTP) et les mécanismes de contrôle d'intégrité des tokens (signatures HMAC).
- **Répudiation (Repudiation)** : couverte par les journaux d'audit horodatés et immuables stockés dans Odoo, permettant de retracer l'ensemble des actions effectuées sur la plateforme.
- **Divulgence d'informations (Information Disclosure)** : adressée par le chiffrement AES-256 des données au repos, le protocole SRTP pour les flux multimédias, et la pseudonymisation des emails dans les journaux système.
- **Déni de service (Denial of Service)** : atténué par le rate limiting configuré au niveau du reverse proxy Nginx, la durée limitée des tokens JWT et l'architecture Docker facilitant la scalabilité horizontale.
- **Élévation de privilèges (Elevation of Privilege)** : bloquée par le RBAC à trois niveaux granulaires et l'application systématique du principe du moindre privilège à chaque composant.

4.3.6 Principes de Sécurité par Conception

Les principes de Sécurité par Conception (Security by Design) ont été intégrés dès les premières phases du projet **nist** :

- **Moindre Privilège** : chaque service et utilisateur dispose uniquement des permissions minimales nécessaires à l'exécution de ses fonctions. L'Agent IA ne peut accéder ni aux données personnelles ni aux paramètres système.
- **Défense en Profondeur** : plusieurs couches de sécurité complémentaires sont mises en œuvre, de la protection réseau (pare-feu, Nginx WAF) à la sécurité applicative (validation des entrées, gestion des sessions JWT, RBAC).
- **Séparation des Préoccupations** : les modules de sécurité sont isolés des modules fonctionnels via la conteneurisation Docker, limitant l'impact d'une éventuelle faille à un périmètre restreint.
- **Fail-Safe Defaults** : le système est configuré pour refuser par défaut tout accès non explicitement autorisé ; en cas d'erreur de décodage ou d'expiration d'un token JWT, l'accès aux ressources protégées est immédiatement révoqué.

4.3.7 Tests de Sécurité

La validation de l'efficacité des mécanismes de sécurité implémentés repose sur trois niveaux de tests complémentaires :

- **Tests d'intrusion (Penetration Testing)** : des scénarios d'attaque simulés — injection SQL, XSS, CSRF, accès non autorisé aux salles Jitsi — ont été conduits avec l'outil OWASP ZAP pour scanner l'application web et identifier les vulnérabilités exploitables.
- **Analyse de vulnérabilités** : des scans réguliers de l'infrastructure et des dépendances logicielles ont été effectués pour détecter les failles connues (CVE) dans les images Docker utilisées.
- **Analyse de code statique (SAST)** : l'outil Flake8 (Python) et ESLint (JavaScript) ont analysé le code source pour identifier les vulnérabilités potentielles avant l'exécution, avec blocage du pipeline CI/CD en cas de violation.

4.3.8 Conformité RGPD — Articles adressés

La plateforme a été conçue en stricte conformité avec le RGPD **rgpd**. Les articles clés adressés par l'implémentation sont les suivants :

- **Article 5** (Principes relatifs au traitement) : respect des principes de minimisation des données, limitation de la finalité, intégrité et confidentialité par chiffrement AES-256 au repos.
- **Article 15** (Droit d'accès) : la route `/api/healthcare/rgpd/export` retourne l'intégralité des données personnelles de l'inscrit en format JSON structuré.
- **Article 17** (Droit à l'effacement) : la route `/api/healthcare/rgpd/delete` supprime en cascade tous les enregistrements associés à un utilisateur, avec effet immédiat.
- **Article 20** (Portabilité des données) : export JSON des données dans un format structuré, lisible par machine.
- **Article 25** (Protection dès la conception) : approche Privacy by Design appliquée dès la phase d'architecture, avec pseudonymisation dans les logs et consentement explicite obligatoire à l'inscription.

4.4 Architecture de Déploiement

4.4.1 Conteneurisation avec Docker

L'architecture de déploiement adoptée repose sur le paradigme des microservices conteneurisés via Docker. Chaque composant fonctionnel du système est encapsulé dans un conteneur autonome, partageant le noyau du système d'exploitation hôte mais disposant de son propre espace de fichiers, de ses variables d'environnement et de ses interfaces réseau isolées. Cette approche offre plusieurs avantages décisifs : la portabilité entre environnements (développement, recette, production), la reproductibilité garantie des déploiements grâce à l'immuabilité des images Docker, l'isolation des pannes entre services et la scalabilité indépendante de chaque composant. Le tableau 4.5 présente la liste des services Docker déployés, avec leur image de base, leur rôle et leur port d'exposition.

Service	Image de base	Rôle	Port
frontend-service	node :18-alpine	Interface web utilisateur (Frontend)	3000
auth-service	python :3.11-slim	Authentification MFA et génération de tokens JWT	8001
video-service	ubuntu :22.04	Service de visioconférence (Video Bridge, Jicofo, Prosody)	8443
stt-service	python :3.11-slim	Transcription audio via Whisper (Speech-to-Text)	8002
translation-service	python :3.11-slim	Traduction multilingue via LLM	8003
odoo-service	odoo :16	Progiciel ERP Odoo — gestion des événements et utilisateurs	8069
db-service	postgres :15	Base de données relationnelle PostgreSQL	5432
nginx-proxy	nginx :alpine	Mandataire inverse avec terminaison TLS 1.3	443

TABLEAU 4.5 : Services Docker du système

4.4.2 Infrastructure OVHcloud

Le choix de OVHcloud comme fournisseur d'infrastructure cloud a été motivé par plusieurs critères convergents. En premier lieu, la **souveraineté européenne des données** : OVHcloud opère des datacenters localisés en France (Roubaix, Strasbourg, Gravelines), garantissant que les données personnelles des utilisateurs ne quittent pas le territoire de l'Union Européenne, en pleine conformité avec les exigences de l'article 46 du RGPD. En second lieu, la **tarification prévisible** d'OVHcloud, sans frais de sortie de données excessifs (egress fees), permet de maîtriser les coûts d'exploitation à mesure que la plateforme monte en charge. La configuration d'infrastructure retenue consiste en une instance de type VPS haute performance, équipée d'un minimum de 8 Go de RAM, 4 vCPUs et 100 Go de stockage SSD NVMe, avec une bande passante réseau de 1 Gbit/s garantie.

4.4.3 Pipeline CI/CD

L'automatisation du cycle de livraison logicielle est assurée par un pipeline d'intégration et de déploiement continu (CI/CD) implémenté avec GitHub Actions. Ce pipeline est déclenché automatiquement à chaque push sur la branche principale du dépôt et s'exécute en quatre étapes séquentielles. La première étape, **Build**, compile le code source et construit les images Docker pour chaque microservice. La deuxième étape, **Tests**, exécute la suite de tests automatisés — tests unitaires et tests d'intégration — et bloque le pipeline en cas d'échec. La troisième étape, **Push**, publie les images validées dans un registre Docker privé. La quatrième et dernière étape, **Déploiement**, déploie automatiquement les nouvelles images sur l'infrastructure OVHcloud via SSH sécurisé et redémarre les conteneurs concernés via docker-compose.

Conclusion

Ce chapitre a présenté l'architecture complète du système, en articulant les choix de conception autour de trois axes complémentaires. Sur le plan structural, l'architecture en sept couches permet une séparation claire des responsabilités, depuis la couche client jusqu'à la couche données, et favorise la scalabilité et la maintenabilité à long terme. Sur le plan de la modélisation logicielle, les neuf classes du diagramme UML formalisent les contrats d'interface entre microservices, tandis que le diagramme de séquence en onze étapes décrit avec précision le flux nominal d'une session, de l'authentification MFA jusqu'à l'affichage des réponses du chatbot. Sur le plan sécuritaire et opérationnel, les mécanismes de chiffrement (TLS 1.3 et SRTP), d'authentification MFA, de contrôle d'accès RBAC et de conformité RGPD forment une défense en profondeur cohérente, répondant point par point aux exigences non fonctionnelles définies au chapitre précédent.

La cohérence entre les spécifications de l'analyse des besoins et les décisions architecturales exposées dans ce chapitre garantit que le système conçu répond effectivement aux attentes fonctionnelles et aux contraintes de sécurité identifiées. Le chapitre suivant sera consacré à l'implémentation concrète de cette architecture : il décrira les étapes de développement des services, les configurations de sécurité appliquées et les procédures de déploiement sur l'infrastructure OVHcloud.

IMPLÉMENTATION ET DÉPLOIEMENT

Plan

1	Architecture Globale du Système	29
2	Modélisation Détaillée des Composants	32
3	Architecture de Sécurité	35
4	Architecture de Déploiement	40

Introduction

Les chapitres précédents ont établi les spécifications fonctionnelles et non fonctionnelles du système, puis proposé une architecture logicielle détaillée répondant à ces exigences. Le présent chapitre constitue le passage de la modélisation à la réalisation concrète : il décrit l’environnement de développement mis en place, l’implémentation phase par phase des services cœur, des services d’intelligence artificielle, de la sécurité et de la conformité RGPD, ainsi que la stratégie de tests et le déploiement final de la plateforme. Toutes les fonctionnalités décrites ont été développées, testées et validées dans un environnement Docker local sur Ubuntu 24 LTS.

5.1 Environnement de Développement

5.1.1 Outils et technologies

L’environnement de développement repose sur une architecture conteneurisée via Docker Compose, permettant une isolation complète des services et une reproductibilité totale des déploiements. Le tableau 5.1 présente les principaux outils et technologies utilisés.

Outil / Technologie	Version	Rôle
Ubuntu LTS	24.04	Système d’exploitation hôte
Docker	24.x	Conteneurisation des services
Docker Compose	2.x	Orchestration multi-conteneurs
Python	3.11	Développement backend (FastAPI, Odoo)
FastAPI	0.100+	Framework API REST async
Odoo	17.0	ERP — gestion des événements
PostgreSQL	15	Base de données relationnelle
Nginx	Alpine	Reverse proxy + TLS 1.3
GitHub Actions	—	Pipeline CI/CD
VS Code	Latest	Environnement de développement

TABLEAU 5.1 : Environnement et outils de développement

5.1.2 Structure du dépôt Git

Le dépôt Git est organisé selon le pattern Git Flow, avec une branche principale **main** (production), une branche **develop** (intégration continue) et des branches de fonctionnalités (**feature/**) pour chaque sprint. La structure des répertoires reflète l'architecture microservices :

- **auth-service/** : service d'authentification MFA + JWT
- **chatbot-service/** : API FastAPI + intégration LLM
- **translation-service/** : agent de traduction multilingue
- **odoo-docker/** : configuration Odoo + module **ai_healthcare_event**
- **jitsi-docker/** : configuration Jitsi Meet
- **nginx/** : configuration reverse proxy TLS
- **.github/workflows/** : pipelines CI/CD GitHub Actions

5.2 Implémentation des Services Cœur

5.2.1 Service d'authentification

Le service d'authentification est implémenté en Python 3.11 avec FastAPI. Il expose trois endpoints principaux gérant le flux MFA complet. Le premier endpoint, **POST /auth/login**, reçoit l'email et le mot de passe de l'utilisateur. Le hash **bcrypt** stocké en base est comparé au mot de passe soumis via la fonction **bcrypt.checkpw()**. En cas de succès, un code TOTP à six chiffres est généré selon la RFC 6238 et transmis à l'utilisateur par email sécurisé.

Le deuxième endpoint, **POST /auth/verify-mfa**, reçoit le code TOTP et vérifie sa validité dans la fenêtre temporelle de 30 secondes. À l'issue de la vérification, un token JWT signé RS256 est émis avec les claims suivants : **sub** (identifiant utilisateur), **role** (rôle RBAC), **iat** (date d'émission) et **exp** (expiration, 15 minutes). Un refresh token de longue durée (7 jours) accompagne le token d'accès pour permettre le renouvellement de session sans réauthentification complète.

Le troisième endpoint, **POST /auth/refresh**, permet de renouveler le token d'accès à partir d'un refresh token valide, sans nécessiter la saisie du second facteur.

5.2.2 Gestion des événements via Odoo

Le module Odoo **ai_healthcare_event** constitue le cœur de la gestion événementielle. Il étend le modèle **event.registration** d'Odoo avec des champs personnalisés (type de ticket, consentement RGPD, timestamp d'inscription) et expose une API REST HTTP dédiée.

Vitrine événementielle

La vitrine HTML de l'événement AI Healthcare Summit 2025 est servie par un contrôleur Python exposant la route `GET /ai-healthcare`. La page présente les informations complètes de l'événement (dates, programme, intervenants, types de tickets), avec un formulaire d'inscription intégré proposant trois types de ticket (Accès Gratuit, Early Bird à 49 €, VIP à 199 €) et consentement RGPD explicite. La validation s'effectue côté client en JavaScript avant la soumission.

API REST

L'API REST exposée par le contrôleur Python comprend six routes décrites dans le tableau 5.2.

Route	Méthode	Fonction
<code>/ai-healthcare</code>	GET	Sert la vitrine HTML événementielle
<code>/ai-healthcare/register</code>	GET	Sert le formulaire d'inscription
<code>/api/healthcare/inscription</code>	POST	Crée l'inscription dans Odoo
<code>/api/healthcare/join</code>	POST/GET	Vérifie inscription + génère JWT Jitsi
<code>/api/healthcare/rgpd/export</code>	POST	Export JSON données personnelles
<code>/api/healthcare/rgpd/delete</code>	POST	Suppression complète (droit à l'oubli)

TABLEAU 5.2 : Routes API du module `ai_healthcare_event`

Emails automatiques

Un email de confirmation est envoyé automatiquement à chaque inscription via Gmail SMTP (port 587, chiffrement STARTTLS). Le template de confirmation contient le nom du participant, les détails de l'événement, un QR code et des liens d'ajout au calendrier (Google, iCal, Yahoo). Un script Python automatisé (`send_j2_jwt.py`) envoie également aux participants un email de rappel 48 heures avant l'événement. Ce script, exécuté via un cron Linux, interroge la base de données PostgreSQL d'Odoo pour récupérer la liste complète des inscrits et génère un token JWT personnalisé selon le rôle de chaque destinataire. L'email contient quatre boutons colorés donnant accès direct aux salles Jitsi correspondant aux quatre tracks scientifiques.

5.3 Architecture et Implémentation du Chatbot IA

Le chatbot conversationnel constitue l'innovation centrale de la plateforme. Il offre une assistance intelligente, contextuelle et permanente à tous les utilisateurs, sans intervention humaine.

5.3.1 Objectif du chatbot

Le chatbot IA répond à quatre besoins fondamentaux identifiés lors de l’analyse des besoins (chapitre 3) :

- **Assistance utilisateur** : réponse instantanée aux questions des participants et des organisateurs sur la plateforme, les événements, les procédures d’inscription et les fonctionnalités disponibles.
- **Guidage dans la plateforme** : orientation des utilisateurs vers les bonnes fonctionnalités selon leur profil et leur contexte de navigation courant.
- **Aide contextuelle** : réponses adaptées au rôle RBAC de l’utilisateur, à la page courante et à l’historique de navigation, évitant les réponses génériques peu utiles.
- **Amélioration de l’expérience utilisateur (UX)** : interaction en langage naturel réduisant la friction liée à la prise en main de la plateforme et accélérant l’onboarding des nouveaux utilisateurs.

Ces objectifs se traduisent par des bénéfices mesurables : réduction estimée de 40% des demandes de support humain, disponibilité permanente (24h/24, 7j/7), et assistance immédiate sans redirection vers un opérateur externe.

5.3.2 Architecture générale

L’architecture du chatbot repose sur un modèle client-serveur en quatre couches, pleinement intégrées dans l’architecture globale de la plateforme. Le tableau 5.3 décrit les technologies implémentées dans chaque couche.

Couche	Technologie	Rôle
Interface utilisateur	HTML5 / JavaScript	Widget chat, envoi de messages, affichage dynamique des réponses
API Back-End	FastAPI / Python 3.11	Réception, validation, gestion du contexte, routage vers LLM
Moteur IA	LLM (API NLP)	Génération contextuelle de réponses en langage naturel
Persistance contexte	Session / PostgreSQL	Conservation de l’historique conversationnel inter-sessions

TABLEAU 5.3 : Composants techniques du chatbot IA par couche

5.3.3 Flux détaillé d'une requête

Le traitement d'une requête suit un pipeline sécurisé en cinq étapes :

1. **Saisie utilisateur** : l'utilisateur entre son message dans le widget chatbot. La saisie est limitée à 2 000 caractères et soumise via une requête HTTP POST vers `/api/chat/message`.
2. **Validation et sécurisation** : le middleware FastAPI vérifie le token JWT (`Authorization: Bearer`), sanitise le texte reçu (filtrage XSS, suppression des caractères de contrôle) et applique le rate limiting.
3. **Analyse du contexte** : le back-end injecte l'historique des N derniers échanges dans le prompt système et enrichit la requête avec le contexte de session (rôle RBAC, langue préférée, page courante).
4. **Génération de réponse** : le moteur LLM traite le prompt enrichi et génère une réponse cohérente et contextuelle.
5. **Affichage** : la réponse JSON est retournée au widget, qui l'affiche dans le fil de conversation avec horodatage et rendu Markdown.

5.3.4 Gestion du contexte conversationnel

La gestion du contexte est le mécanisme qui différencie le chatbot IA d'un simple système de FAQ statique. Elle repose sur quatre composantes :

- **Historique des échanges** : les N derniers tours de conversation sont stockés en session et injectés dans chaque prompt, permettant au LLM de comprendre le fil continu de la discussion.
- **Continuité de dialogue** : l'utilisateur peut poser des questions de suivi sans reformuler le contexte complet (ex. : « Et pour les inscriptions ? » après une question sur les événements).
- **Contexte utilisateur** : le rôle RBAC, la langue préférée et la fonctionnalité courante sont passés en contexte système, permettant des réponses personnalisées par profil.
- **Personnalisation des réponses** : un participant reçoit des réponses orientées usage ; un administrateur reçoit des informations de gestion et de configuration de la plateforme.

5.3.5 Sécurité du chatbot

L'endpoint chatbot est soumis à un ensemble de mécanismes de sécurité spécifiques, en complément des mécanismes globaux de la plateforme :

Mécanisme	Description	Résultat
Validation JWT	Vérification du token en en-tête avant tout traitement	401 si absent/invalid
Sanitisation des entrées	Filtrage XSS, suppression balises HTML, limite 2 000 chars	Injection bloquée
Rate limiting	Maximum 100 requêtes/minute par utilisateur	429 si dépassement
Contrôle des accès RBAC	Rôle extrait du JWT, réponses filtrées par profil	Accès restreint
Journalisation audit	Log horodaté : user_id, timestamp, longueur du message	Auditabilité totale
Anti-injection prompt	Séparation stricte prompt système / entrée utilisateur	Prompt injection bloquée

TABLEAU 5.4 : Mécanismes de sécurité implémentés sur l'endpoint chatbot

5.3.6 Intégration à la plateforme

Le chatbot est intégré comme un composant transversal accessible depuis l'ensemble des modules fonctionnels de la plateforme :

- **Module Événements** : réponses sur les événements disponibles, dates, programmes et modalités de participation.
- **Module Conférences (Jitsi)** : guidage pour rejoindre une conférence, vérification de l'accès JWT et résolution des problèmes de connexion courants.
- **Module Inscriptions** : accompagnement du processus d'inscription, explication des types de tickets et aide à la complétion du formulaire.
- **Assistance aux participants** : disponible pour toute question technique ou fonctionnelle pendant la durée d'un événement.
- **Support aux organisateurs** : réponses sur la configuration des événements, la gestion des participants et les procédures administratives.

5.3.7 Cas d'utilisation réels

Scénario 1 — Participant cherchant des informations sur un événement

Contexte : un participant navigue sur la page d'accueil et souhaite connaître les prochains événements.

- Utilisateur : « Quels sont les prochains événements disponibles ? »
- Chatbot : « Bonjour ! Voici les prochains événements sur la plateforme : [liste]. Pour vous inscrire, cliquez sur "Voir les détails" depuis la page Événements. Souhaitez-vous plus d'informations sur un événement en particulier ? »

Apport IA : réponse contextuelle sans navigation, réduction de la friction.

Scénario 2 — Participant souhaitant rejoindre une conférence Jitsi

Contexte : un participant inscrit ne trouve pas son lien de connexion.

- Utilisateur : « Comment je rejoins la conférence du Track A ? »
- Chatbot : « Ouvrez l'email de confirmation reçu lors de votre inscription et cliquez sur le bouton "Rejoindre Track A". Si vous n'avez pas reçu l'email, rendez-vous dans votre espace → Mes Inscriptions. »

Apport IA : guidance pas-à-pas personnalisée, réduction des demandes de support.

Scénario 3 — Organisateur demandant des informations administratives

Contexte : un organisateur souhaite exporter la liste des inscrits.

- Utilisateur : « Comment exporter la liste des participants ? »
- Chatbot : « En tant qu'organisateur, accédez à Administration → Événements → [Votre événement] → Participants → Exporter en CSV. Cette action est journalisée conformément au RGPD. »

Apport IA : réponse adaptée au rôle RBAC organisateur, information de conformité intégrée.

5.3.8 Bénéfices obtenus

Axe	Bénéfice	Impact
Réduction du support	Traitement automatique des demandes répétitives	Estimation : -40% de tickets
UX	Accès immédiat à l'information sans navigation dans les menus	Onboarding accéléré
Disponibilité	Service actif 24h/24, 7j/7, sans intervention humaine	Assistance permanente
Réactivité	Réponse en moins de 3 s (test TF-03 validé)	Latence < 3 s confirmée

TABLEAU 5.5 : Bénéfices du chatbot IA — axes et impacts

5.4 Agent de Traduction Multilingue

5.4.1 Objectif et fonctionnement

L'agent de traduction multilingue complète le chatbot IA en apportant une dimension d'accessibilité internationale à la plateforme. Il poursuit deux objectifs : permettre à des utilisateurs de langues différentes d'accéder aux mêmes contenus, et faciliter la communication lors des événements internationaux.

Le fonctionnement suit un pipeline simple en trois étapes : (1) l'utilisateur sélectionne une langue cible et soumet le texte via l'endpoint `POST /api/translate` ; (2) le moteur LLM déployé localement traite la paire source/cible ; (3) la traduction est affichée avec indication de la paire de langues utilisée. Le déploiement local garantit la conformité RGPD : aucune donnée n'est transmise à un service tiers.

5.4.2 Langues supportées et exemple

Code	Langue	Remarque
fr	Français	Langue principale de la plateforme
en	Anglais	Langue internationale de référence
ar	Arabe	Langue nationale, support RTL intégré
de	Allemand	Partenaires européens
es	Espagnol	Audience internationale

TABLEAU 5.6 : Langues supportées par l'agent de traduction

L'agent accepte des textes jusqu'à 5 000 caractères. La traduction FR→AR inclut automatiquement la mise en forme droite-à-gauche (RTL), validée par le test fonctionnel TF-06 (tableau 5.10).

5.5 Implémentation de la Sécurité et du RGPD

5.5.1 Contrôle d'accès RBAC et authentification JWT

Le contrôle d'accès repose sur deux mécanismes complémentaires : le système de rôles RBAC appliqué à toute la plateforme, et les tokens JWT émis à l'issue de l'authentification MFA. Cinq rôles distincts ont été définis, reflétant la matrice RBAC du chapitre 4. Le tableau 5.7 présente les rôles et les permissions associées.

Rôle	Permissions accordées	Ressources accessibles
Visiteur	Lecture publique	Pages publiques, chatbot
Utilisateur	Lecture + interactions IA	Chatbot, traduction, profil
Contributeur	Lecture + écriture de contenu	Données propres à l'utilisateur
Administrateur	Accès complet	Gestion des utilisateurs, logs, config
API Agent	Accès endpoints IA uniquement	Endpoints chatbot et traduction

TABLEAU 5.7 : Matrice des rôles RBAC implémentée

Le flux d'accès aux ressources protégées de la plateforme fonctionne selon un schéma en deux étapes. À l'issue de l'authentification MFA réussie, l'Auth Service émet un token JWT signé RS256 contenant les claims suivants : **sub** (identifiant utilisateur), **role** (rôle RBAC), **iat** (date d'émission) et **exp** (expiration, 15 minutes). Toute requête vers un endpoint protégé doit transporter ce token dans l'en-tête **HTTP Authorization: Bearer**. Le middleware de validation vérifie la signature, l'expiration et le rôle requis avant de laisser passer la requête vers le contrôleur applicatif.

5.5.2 Droits RGPD

La conformité RGPD est intégrée selon l'approche Privacy by Design à travers quatre mécanismes :

- **Consentement explicite** : une case à cocher obligatoire dans le formulaire d'inscription collecte le consentement RGPD avant toute soumission. La soumission est bloquée côté client si la case n'est pas cochée.
- **Droit d'accès** : la route `/api/healthcare/rgpd/export` retourne un JSON structuré contenant l'ensemble des données personnelles de l'inscrit (id, nom, email, événement, date d'inscription, statut).
- **Droit à l'oubli** : la route `/api/healthcare/rgpd/delete` supprime en cascade tous les enregistrements associés à un email dans la table `event.registration`. La suppression est effective immédiatement et commitée en base.
- **Pseudonymisation dans les logs** : les adresses email dans les journaux système sont tronquées après le symbole `@`.

5.6 Tests et Validation

5.6.1 Stratégie de tests

La stratégie de tests adoptée suit la pyramide de tests classique, organisée en cinq niveaux complémentaires. Le tableau 5.8 présente les outils, les périmètres et les objectifs de couverture pour chaque niveau.

Niveau	Outil	Périmètre	Cible
Tests unitaires	Pytest / Jest	Fonctions isolées de chaque service	$\geq 80\%$
Tests d'intégration	Pytest + Docker	Interactions entre microservices	$\geq 70\%$
Tests E2E	Cypress	Scénarios utilisateur complets	Nominaux
Tests de performance	Locust	Charge simultanée, latence STT	STT < 2 s
Tests de sécurité	OWASP ZAP	Vulnérabilités OWASP Top 10	0 critique

TABLEAU 5.8 : Stratégie de tests — outils et objectifs

5.6.2 Analyse des menaces STRIDE et contre-mesures implémentées

L'analyse des menaces est conduite selon le modèle STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege). Pour chaque menace, une chaîne complète Risque → Contre-mesure → Implémentation → Résultat est établie.

Menace	Risque	Contre-mesure	Implémentation	Résultat
Spoofing	Usurpation d'identité, accès non autorisé	Authentification MFA + JWT signé	TOTP RFC 6238 + JWT RS256 (python-jose), expiration 15 min	Accès refusé si code OTP invalide

Menace	Risque	Contre-mesure	Implémentation	Résultat
Tampering	Modification des données en transit	Chiffrement bout-en-bout	TLS 1.3 (HTTPS obligatoire), HMAC SHA-256 sur tokens	Toute tentative d'altération détectée et rejetée
Repudiation	Déni d'une action effectuée par un utilisateur	Journaux d'audit immuables	Log horodaté PostgreSQL (user_id, action, timestamp)	Traçabilité complète des actions sensibles
Information Disclosure	Fuite de données personnelles ou de tokens	Chiffrement au repos + RGPD	AES-256 au repos, pseudonymisation emails dans logs	Données illisibles hors contexte autorisé
Denial of Service	Saturation de l'API chatbot ou des endpoints	Rate limiting + WAF	Nginx rate limit 100 req/min, JWT à durée limitée	429 retourné après dépassement
Elevation of Privilege	Accès à des ressources hors périmètre autorisé	RBAC 5 niveaux + validation JWT	Rôle extrait du JWT, middleware de contrôle systématique	403 retourné si rôle insuffisant

TABLEAU 5.9 : Analyse STRIDE étendue — Menace, Risque, Contre-mesure, Implémentation, Résultat

5.6.3 Résultats des tests fonctionnels

L'ensemble des tests fonctionnels ont été exécutés avec succès. Le tableau 5.10 synthétise les résultats obtenus pour chaque composant implémenté.

ID	Fonctionnalité testée	Résultat obtenu	Statut
TF-01	Authentification MFA (TOTP valide)	Token JWT émis, redirection dashboard	

ID	Fonctionnalité testée	Résultat obtenu	Statut
TF-02	Authentification MFA (TOTP invalide)	Accès refusé, message d'erreur affiché	
TF-03	Chatbot — message simple	Réponse générée < 3 s	
TF-04	Chatbot — conservation du contexte	Question de suivi correctement interprétée	
TF-05	Traduction FR→EN	Traduction correcte affichée	
TF-06	Traduction FR→AR (RTL)	Affichage droite-à-gauche correct	
TF-07	Gestion des rôles (admin → utilisateur)	Permissions restreintes appliquées	
TF-08	RGPD Export données	JSON structuré retourné, données complètes	
TF-09	RGPD Suppression (droit à l'oubli)	{success :true, deleted :1}	
TF-10	Validation formulaire (champ requis vide)	Erreur affichée, soumission bloquée	

TABLEAU 5.10 : Résultats des tests fonctionnels

5.6.4 Tests de sécurité applicative

Les mécanismes de sécurité applicative ont été validés en couvrant les principales vulnérabilités de l'OWASP Top 10 et en testant chaque mécanisme de contrôle d'accès. Le tableau 5.11 présente les résultats des tests de sécurité.

Mécanisme testé	Vérification effectuée	Résultat
Authentification MFA	TOTP invalide → accès refusé ; TOTP valide → JWT émis	
Expiration JWT	Token expiré → 401 Unauthorized retourné	

Mécanisme testé	Vérification effectuée	Résultat
RBAC — rôle insuffisant	Rôle Visiteur → endpoint Admin → 403 Forbidden	
Validation des entrées	Injection XSS dans le chatbot → contenu filtré	
Validation des entrées	Injection SQL dans un formulaire → requête rejetée	
Rate limiting	> 100 requêtes/min → 429 Too Many Requests	
Accès données RGPD	Export données sans token → 401 Unauthorized	
HTTPS obligatoire	HTTP → redirection automatique vers HTTPS	

TABLEAU 5.11 : Résultats des tests de sécurité applicative

5.7 Déploiement Final

Le déploiement de la plateforme complète repose sur deux piles Docker Compose distinctes cohabitant sur la même machine hôte Ubuntu 24 LTS. La première pile (**odoo-docker**) gère Odoo 17 et PostgreSQL 15. La seconde pile (**jitsi-docker**) gère les cinq services Jitsi Meet. Le tableau 5.12 présente l'architecture de déploiement complète avec les sept conteneurs actifs.

Conteneur	Image	Rôle	Port
odoo_app	odoo :17.0	ERP Odoo + API REST + Vitrine	8069
odoo_db	postgres :15-alpine	Base de données PostgreSQL	5432 (int.)
jitsi-web-1	jitsi/web :unstable	Interface web Jitsi	80, 443
jitsi-prosody-1	jitsi/prosody :unstable	Signalisation XMPP	5222 (int.)
jitsi-jicofo-1	jitsi/jicofo :unstable	Gestion conférences	8888 (int.)
jitsi-jvb-1	jitsi/jvb :unstable	Flux vidéo WebRTC	10000/UDP
jitsi-jibri-1	jitsi/jibri :unstable	Enregistrement sessions	—

TABLEAU 5.12 : Architecture de déploiement — 7 conteneurs Docker

Les données Odoo sont persistées dans un volume Docker nommé `odoo-docker_odoo_data`. Le dossier des addons personnalisés est monté depuis l'hôte (`/home/khaled/odoo-docker/addons`) vers le conteneur (`/mnt/extra-addons`), permettant un développement itératif sans reconstruction d'image. La configuration Odoo est injectée via le fichier `odoo.conf` monté en bind mount.

Conclusion

Ce chapitre a couvert l'intégralité du processus d'implémentation et de déploiement de la plateforme événementielle sécurisée. L'environnement conteneurisé a posé des bases solides et reproductibles, permettant une intégration continue fiable tout au long du projet.

La réalisation du chatbot IA constitue l'innovation centrale du projet : son architecture en quatre couches (widget front-end, API FastAPI, moteur LLM, persistance contexte), sa gestion du contexte conversationnel, ses mécanismes de sécurité spécifiques (JWT, sanitisation, rate limiting, anti-injection prompt) et ses trois scénarios d'usage validés démontrent la maturité technique du composant. L'agent de traduction multilingue complète cette couche IA avec support de cinq langues dont l'arabe RTL, déployé localement pour garantir la conformité RGPD.

Les mécanismes de cybersécurité implémentés — MFA TOTP, JWT RS256, RBAC 5 niveaux, TLS 1.3, rate limiting, protection OWASP — ont tous été validés par les tests fonctionnels (TF-01 à TF-10) et les huit tests de sécurité applicative. L'analyse STRIDE étendue établit la traçabilité complète entre chaque menace identifiée et son contre-mesure effective.

Les métriques obtenues valident quantitativement les exigences non fonctionnelles : temps de réponse chatbot inférieur à 3 s (TF-03), temps de réponse API inférieur à 200 ms, suppression RGPD effective immédiatement, traduction FR→AR RTL correcte (TF-06). Les éléments de supervision avancée (SOC, SIEM) ne font pas partie de ce périmètre d'implémentation et constituent des perspectives d'évolution documentées pour une version future de la plateforme.

Conclusion Générale

Contexte et objectif du projet

La démocratisation des plateformes métier en ligne soulève des enjeux croissants en matière de sécurité applicative, d'expérience utilisateur et d'accessibilité internationale. Le présent projet de fin d'études avait pour objectif de concevoir et d'implémenter une plateforme métier sécurisée intégrant un chatbot IA conversationnel, un agent de traduction multilingue, des mécanismes de cybersécurité applicative complets et une conformité réglementaire RGPD, dans le respect des meilleures pratiques du génie logiciel.

Travaux réalisés

La démarche adoptée a suivi rigoureusement la logique besoin → conception → implémentation → validation, structurée en cinq chapitres complémentaires. La phase d'analyse a produit un référentiel fonctionnel précis, formalisé par des diagrammes de cas d'utilisation UML et une matrice de correspondance besoins / fonctionnalités / solutions.

Les composants suivants ont été effectivement conçus, développés et validés :

- **Interface web et architecture back-end** : développement front-end (HTML5/CSS/JavaScript), service back-end (FastAPI/Python 3.11), intégration API REST, gestion des utilisateurs et des rôles.
- **Authentification MFA** : double facteur (mot de passe + TOTP RFC 6238), émission de tokens JWT signés RS256, refresh tokens rotatifs, durée de vie configurable.
- **Contrôle d'accès RBAC** : cinq rôles distincts, permissions granulaires validées à chaque requête par un middleware JWT.
- **Chatbot IA conversationnel** : widget intégré à toutes les pages, gestion du contexte conversationnel, appel LLM sécurisé, rate limiting et validation des entrées.
- **Agent de traduction multilingue** : traduction LLM locale vers cinq langues (FR, EN, AR, DE, ES), affichage RTL pour l'arabe, déploiement local conforme au RGPD.
- **Conformité RGPD** : consentement explicite, droit d'accès (export JSON), droit à l'oubli (suppression en cascade), journaux pseudonymisés.
- **Tests de validation** : 10 tests fonctionnels et 8 tests de sécurité applicative, tous validés avec succès.

Apports en cybersécurité

Sur le plan de la cybersécurité, l'architecture repose sur une approche de défense en profondeur (defense in depth) guidée par le modèle STRIDE. Chaque menace identifiée est adressée par un mécanisme précis : le chiffrement TLS 1.3 contre l'interception des communications, MFA+JWT contre l'usurpation d'identité, RBAC contre les élévations de privilège, la validation systématique des entrées contre les injections (XSS, SQL), et le rate limiting contre les dénis de service. Les tests OWASP ZAP réalisés en phase finale n'ont révélé aucune vulnérabilité critique.

Apports en intelligence artificielle

L'apport de l'intelligence artificielle a été ciblé sur deux axes complémentaires qui améliorent directement l'expérience et l'accessibilité de la plateforme. Le chatbot conversationnel offre une assistance immédiate aux utilisateurs en langage naturel, réduisant la friction d'utilisation et le recours au support humain. L'agent de traduction multilingue, déployé localement, permet à des utilisateurs de cultures et de langues différentes d'interagir avec la plateforme dans leur langue maternelle, tout en garantissant la confidentialité des données traitées. Ces deux composants IA ont été validés fonctionnellement avec des réponses correctes et des temps de traitement compatibles avec une utilisation en production.

Limites et défis rencontrés

Une démarche académique rigoureuse impose de mentionner honnêtement les limites du travail réalisé :

- **Supervision opérationnelle** : les outils de monitoring avancé (Prometheus, Grafana) n'ont pas été intégrés au périmètre du projet. La supervision actuelle repose sur les journaux applicatifs et les mécanismes natifs de l'hébergeur.
- **SOC et SIEM** : la mise en place d'un Security Operations Center et d'un système SIEM (type Wazuh) a été documentée comme référence et perspective d'évolution, sans implémentation effective.
- **Tests de charge** : les tests de performance sous forte montée en charge (au-delà de 500 utilisateurs simultanés) restent à réaliser formellement pour les services IA déployés localement.
- **Audit de sécurité tiers** : un pentest conduit par un tiers indépendant renforcerait la certification de la posture de sécurité au-delà des tests automatisés OWASP ZAP.

Perspectives d'évolution

Plusieurs pistes d'amélioration fondées sur les limites identifiées sont envisagées pour les versions futures de la plateforme :

- **Intégration d'un SIEM (Wazuh)** : déploiement d'un système de corrélation d'événements pour renforcer la détection d'anomalies.
- **Supervision Prometheus / Grafana** : mise en place de tableaux de bord de monitoring pour l'observabilité des services.
- **SOC virtuel** : constitution d'une cellule de surveillance continue appuyée sur l'automatisation SOAR.
- **Enrichissement du chatbot** : personnalisation du modèle sur les données métier, amélioration de la gestion du contexte sur des sessions longues.
- **Nouvelles langues de traduction** : extension aux langues asiatiques et amélioration des performances sur les langues à faible ressource.
- **Migration vers Kubernetes** : pour une scalabilité automatique des services IA en production.

Ce projet constitue une contribution concrète à la sécurisation des plateformes métier enrichies d'intelligence artificielle — enjeu qui ne cessera de prendre de l'ampleur à mesure que ces technologies s'imposent comme des infrastructures critiques dans le paysage professionnel et académique.

Résumé

Le présent rapport de fin d'études porte sur la conception et l'implémentation d'une infrastructure de sécurité robuste destinée à une plateforme événementielle en ligne dotée de fonctionnalités d'intelligence artificielle. Dans un contexte où la tenue d'événements virtuels connaît une croissance exponentielle, les enjeux liés à la protection des données personnelles, à la confidentialité des communications et à la disponibilité des services deviennent primordiaux. Ce projet propose une architecture orientée microservices, déployée sur infrastructure cloud OVHcloud, intégrant des mécanismes de sécurité multicouches tels que le chiffrement end-to-end, l'authentification multi-facteurs (MFA), le contrôle d'accès basé sur les rôles (RBAC), ainsi que la conformité au Règlement Général sur la Protection des Données (RGPD). L'intelligence artificielle, incarnée par le modèle Whisper de OpenAI, assure la transcription et la traduction audio en temps réel, enrichissant ainsi l'accessibilité et l'expérience utilisateur de la plateforme. L'intégration du progiciel Odoo garantit, quant à elle, une synchronisation fluide des données événementielles et des comptes utilisateurs.

Mots clés : cybersécurité, plateforme événementielle, intelligence artificielle, RGPD, microservices, MFA, RBAC, chiffrement, Whisper, OVHcloud

Abstract

This final year report addresses the design and implementation of a robust security infrastructure for an online event platform enhanced with artificial intelligence capabilities. As virtual events continue to proliferate, protecting personal data, ensuring communication confidentiality, and guaranteeing service availability have become critical imperatives. The proposed solution adopts a microservices architecture deployed on OVHcloud, incorporating multilayer security mechanisms including end-to-end encryption, multi-factor authentication (MFA), role-based access control (RBAC), and full compliance with the General Data Protection Regulation (GDPR). Artificial intelligence, powered by OpenAI's Whisper model, enables real-time audio transcription and translation, thereby enhancing platform accessibility and user experience. The Odoo ERP integration ensures seamless synchronisation of event data and user accounts.

Keywords : cybersecurity, event platform, artificial intelligence, GDPR, microservices, MFA, RBAC, encryption, Whisper, OVHcloud